سياسة أمن المعلومات وحماية البيانات

حزمة سياسات ولوائح القطاع غير الربحي

منصة دفة للتخطيط الاستراتيجي وصناعة السياسات

الإصدار 3.0 | 06 نوفمبر 2026	DAF-ICT-01

التقنية والإعلام والأخلاقيات

نموذج مهني استرشادي

يُستكمل ببيانات الجهة وحقول التخصيص، ويخضع للمراجعة المهنية وقرار الاعتماد والموافقات النظامية اللازمة قبل الاستخدام.

Word + PDF • نموذجًا مطورًا • 4 مجموعات 19

سياسة أمن المعلومات وحماية البيانات الشخصية

نموذج استرشادي موسَّع وقابل للتخصيص — منهجية دفة لبناء السياسات

- كود الوثيقة: DAF-ICT-01
- الإصدار: 3.0
- تاريخ الإصدار: 2026/11/06
- التصنيف: التقنية والإعلام والأخلاقيات
- حالة الوثيقة: نموذج مهني استرشادي لا يُصبح معتمدًا إلا بعد استكمال بيانات الجهة في حقول التخصيص (المبحث 18) وإصدار قرار الاعتماد من مجلس الإدارة أو مجلس الأمناء، مع موافقة الجهة المشرفة و/أو المركز الوطني لتنمية القطاع غير الربحي عندما تتطلب الأنظمة ذلك.
- الوثائق المكملة: DAF-GOV-05 (مصفوفة الصلاحيات والتفويض)، DAF-ICT-02 (تقنية المعلومات وإدارة الخدمات الرقمية، بما فيها حوكمة الذكاء الاصطناعي)، DAF-COM-01 (السياسة الإعلامية وإدارة المحتوى والقنوات)، DAF-CMP-01 (مكافحة غسل الأموال وتمويل الإرهاب)، DAF-FIN-01 (الشؤون المالية والمحاسبية)، DAF-FIN-02 (جمع التبرعات وإدارة الحملات)، ووثائق الموارد البشرية المعنية.
- رمز الوثيقة القالب: [اسم الجهة]-POL-ICT-01 — تُستخدم «DAF» في هذا القالب رمزًا تعبئيًا تستبدله الجهة باسمها أو رمزها المعتمد في جميع مراجع السياسة (DAF-POL-ICT-01-XX).

قاعدة التعارض (تُقرأ قبل أي حكم في هذه الوثيقة): تُسود الأنظمة واللوائح والقرارات الصادرة من الجهات المختصة (وسدايا باعتبارها الجهة المختصة بحماية البيانات الشخصية) على أي حكم في هذه الوثيقة، وتُسود اللوائح الأساسية أو التنظيمية المعتمدة للجهة على أحكام التخصيص الداخلية. لا يجوز استخدام أحكام التخصيص لتخفيض حق نظامي أو تجاوز اختصاص أو الإحالة إلى هذه السياسة للتحلل من التزام صريح في نظام أو لائحة. وعند تعارض نص في هذه الوثيقة مع نص نظامي نافذ يُعمل بالنص النظامي وتُحدَّث الوثيقة في أول مراجعة.

قاعدة المتابعة التشريعية: يكثّف المشهد التنظيمي في المملكة خلال عامي 2025–2026م؛ فسدايا أجرت جولات استطلاع عامة لتعديل اللائحة التنفيذية لنظام حماية البيانات الشخصية، وآخرها مسودة نُشرت للاستطلاع من 6 أكتوبر 2026م حتى 5 نوفمبر 2026م[8]. تلتزم الجهة بمتابعة ما يُعتمد من تعديلات عبر بوابة سدايا للأنظمة واللوائح ومنصة الاستطلاع (إستطلاع)، وتُحدِّث هذه الوثيقة خلال مدة لا تتجاوز ستين يومًا من نفاذ أي تعديل.

سجل الوثيقة

العنصر	البيان
إعداد المحتوى ومراجعته المهنية	.....
المراجعة النظامية والقانونية	.....
قرار الاعتماد ورقمه وتاريخه	.....
تاريخ النفاذ وموعد المراجعة التالية	.....
اسم الجهة ورقم ترخيصها وجهة الإشراف عليها	.....
اسم المفوض بالتوقيع وصفته وتوقيعه	.....
موافقة الجهة المشرفة/المركز الوطني إن لزمت نظامًا	.....
رقم شهادة التسجيل في السجل الوطني للمسؤولين (منصة حوكمة البيانات) وتاريخ انتهائها	.....

العنصر	البيان
بيانات مسؤول حماية البيانات كما سُجلت لدى سدايا	.....

المبحث 1: التعريف بالوثيقة ومرجعيتها

1.1 الغرض

تُرسي هذه الوثيقة منظومة متكاملة لأمن المعلومات وحماية البيانات الشخصية في الجهة، تجمع بين ضبط حركة البيانات عبر دورة حياتها الكاملة (من الجمع المشروع إلى الإتلاف الآمن) وحمايتها بالضوابط التقنية والتنظيمية والبشرية، وإدارة حوادثها ونقلها ومشاركتها، بما يوافق نظام حماية البيانات الشخصية الصادر بالمرسوم الملكي رقم (م/19) المعدل بالمرسوم الملكي رقم (م/148)[1] ولائحته التنفيذية[2]، ويلتقي في أبعاد الأمن السيبراني مع الضوابط الأساسية للأمن السيبراني (ECC-2:2024) الصادرة عن الهيئة الوطنية للأمن السيبراني[9] ومعيار إدارة أمن المعلومات ISO/IEC 27001:2022[11]، وبما يتناسب مع طبيعة الجهات غير الربحية ومواردها وبيانات مستفيديها المتبرعين وموظفيها ومتطوعيها.

1.2 الأهداف

1. حماية البيانات الشخصية التي تتعامل معها الجهة من الاختراق والفقدان والإفصاح غير المشروع، وصون حقوق أصحابها (المستفيدون، المتبرعون، الموظفون، المتطوعون، الشركاء) وفق النظام.
2. ترسيخ مبدأ الامتثال القائم على إثبات الامتثال (Accountability): أن تُوثق الجهة كل معالجة قبل البدء بها لا أن تكتفي بالامتثال الشكلي، عبر سجل معالجة البيانات، وتقييمات الأثر، والموافقات، والسجلات القابلة للعرض على الجهة المختصة عند الطلب[16].
3. بناء ثقافة سيبرانية واعية لدى الموظفين والمتطوعين تقلل الأخطاء البشرية التي تُعد السبب الأول لحوادث الاختراق.
4. ضمان جاهزية الجهة لإدارة حوادث البيانات والاستجابة لها وفق دليل سدايا لإجراءات حوادث اختراق البيانات الشخصية[4]، بما في ذلك إشعار الجهة المختصة خلال (72) ساعة وإخطار المتضررين دون تأخير مفرط.
5. ضبط مشاركة البيانات مع المعالجين والأطراف الخارجية والنقل عبر الحدود بضوابط تعاقدية وتقنية تكفل بقاء البيانات محمية.
6. تمكين الجهة من أداء رسالتها الإنسانية باستخدام الأدوات الرقمية (الجمع الإلكتروني للتبرعات، إدارة المستفيدين، التقارير للمانحين) دون تعريض بيانات الأفراد للخطر.
7. حماية الجهة من الجزاءات النظامية والإدارية والمدنية (الغرامات التي تصل إلى خمسة ملايين ريال وتُضاعَف عند التكرار، والعقوبات الجنائية على الإفصاح عن بيانات حساسة بقصد الإضرار، والتعويض عن الضرر)[17]، وحماية سمعتها وثقة المتبرعين والمانحين بها.
8. مواءمة ممارسات الجهة مع أفضل المعايير الدولية (ISO/IEC 27001:2022، وإطار NIST CSF 2.0)[14] لتيسير الشراكات الدولية والحصول على التمويل والاعتمادات.

1.3 نطاق التطبيق

تسري هذه الوثيقة على:

- الأشخاص: أعضاء مجلس الإدارة أو الأمناء، المدير التنفيذي (الأمين العام/الرئيس التنفيذي)، الموظفون بعقود دائمة ومؤقتة، المتطوعون والمندوبون والمؤثرون المتعاقد معهم، المستشارون والمقاولون، وأي شخص يُمنح صلاحية وصول إلى أنظمة الجهة أو بياناتها بأي صفة.
- البيانات: جميع البيانات الشخصية التي تجمعها الجهة أو تعالجها أو تخزنها أو تشاركها أو تُتلفها، بأي وسيلة كانت (ورقية إلكترونية، أو صوتية أو مرئية)، وفي أي نظام أو قاعدة بيانات أو ملف أو جهاز تابع للجهة أو تحت سيطرتها.
- الأنظمة والأصول: الأجهزة (المحمولة والمكتبية والخوادم)، الشبكات، التطبيقات والمواقع الإلكترونية، منصات جمع التبرعات، حسابات البريد والخدمات السحابية، وأي أصل معلوماتي يعالج بيانات الجهة.
- الأماكن: المقر الرئيسي والفروع والمواقع المؤقتة (الفعاليات) والعمل عن بُعد، داخل المملكة وخارجها متى كانت الجهة طرفًا في المعالجة.

(DAF-POL-ICT-01-03) لا يُستثنى من هذا النطاق أي تعامل مع بيانات شخصية يجري باسم الجهة أو لحسابها، بما في ذلك ما يجريه المتطوعون بأجهزتهم الشخصية، وما تجريه أنظمة المانحين والشركاء نيابة عنها؛ ويتحمل كل من يعمل في نطاق الجهة — بأي صفة — الالتزام بأحكام هذه الوثيقة.

(DAF-POL-ICT-01-01) لا يجوز لأي إجراء أو ممارسة داخل الجهة أن يخالف أحكام هذه الوثيقة؛ فإذا تعارض عمل متعارف عليه معها عُلِّق العمل وأُحيل الأمر فورًا إلى مسؤول حماية البيانات والمسؤول التنفيذي لاتخاذ قرار المخالفة المبررة أو تعديل الممارسة، ويُدوَّن القرار ومبرره.

(DAF-POL-ICT-01-02) تُراجع هذه الوثيقة دوريًا كل سنة من تاريخ نفاذها أو عند حدوث أي مما يلي، أيهما أقرب: تعديل تشريعي أو تنظيمي مؤثر، أو حادثة بيانات جوهرية، أو تغيير جوهري في أنظمة الجهة أو خدماتها (إطلاق منصة جديدة، معالجة بيانات حساسة جديدة)، أو ملاحظة مراجعة داخلية أو خارجية جوهرية، أو صدور تعديلات نافذة على اللائحة التنفيذية لنظام حماية البيانات الشخصية.

1.4 المرجعية النظامية والمعيارية

المرجع	طبيعته	الأثر في هذه الوثيقة
نظام حماية البيانات الشخصية (م/19) المعدل بم/148[1]	نظام ملزم	حقوق الأفراد، الأسس النظامية للمعالجة، الحوادث، النقل عبر الحدود، الجزاءات
اللائحة التنفيذية لنظام حماية البيانات الشخصية[2]	لائحة ملزمة	إشعار الخصوصية، السجل الوطني، تسجيل المسؤولين، ضوابط التسويق، الاحتفاظ بالسجلات
لائحة نقل البيانات الشخصية خارج المملكة (الإصدار 2.0)[3]	لائحة ملزمة	شروط النقل، البنود التعاقدية النموذجية، قواعد الربط الملزمة، تقييم المخاطر
دليل إجراءات حوادث اختراق البيانات الشخصية[4]	دليل إجرائي ملزم عمليًا	مراحل الإشعار خلال 72 ساعة، محتوى الإخطار، إخطار أصحاب البيانات
قواعد السجل الوطني للمسؤولين داخل المملكة[5]	قواعد ملزمة	التسجيل في منصة الحوكمة الوطنية للبيانات وتحديث البيانات
قواعد تعيين مسؤول حماية البيانات الشخصية[6]	قواعد ملزمة	حالات وجوب التعيين وشروط شاغر الوظيفة
البنود التعاقدية النموذجية (SCCs) وقواعد الربط الملزمة (BCRs)[7]	أدوات نظامية معتمدة	الضمانات المناسبة للنقل عبر الحدود
مسودة تعديلات اللائحة التنفيذية (استطلاع 6 أكتوبر – 5 نوفمبر 2026م)[8]	مسودة قيد الاستطلاع	بند متابعة: التخزين داخل المملكة، توسيع التسجيل والإشعار، مهلة الرد على سدايا
الضوابط الأساسية للأمن السيبراني ECC-2:2024[9]	ضوابط معتمدة من الهيئة الوطنية للأمن السيبراني (إلزامية للجهات الحكومية والبنية التحتية الحيوية، وموصى بها بقوة لغيرهما)	خط الأساس التقني: الحوكمة، الحماية، المرونة، الأطراف الثالثة والسحابة
ضوابط أمن البيانات (DCC) وضوابط أمن الحوسبة السحابية (CCC)[10]	ضوابط قطاعية	تعميق ضوابط حماية البيانات والخدمات السحابية
ISO/IEC 27001:2022[11]	معيار دولي	إدارة أمن المعلومات والضوابط (93 ضابطًا)
نظام مكافحة الجرائم المعلوماتية[12]	نظام ملزم	الجرائم المعلوماتية وما يترتب عليها من جزاءات
نظام التعاملات الإلكترونية[13]	نظام ملزم	الاعتراف بالتوقيع الإلكتروني والسجلات الإلكترونية
إطار NIST CSF 2.0[14]	إطار دولي إرشادي	إدارة مخاطر الأمن السيبراني (حوكمة، تعرف، حماية، رد، تعافٍ، تعلم)

المرجع	طبيعته	الأثر في هذه الوثيقة
إطار تبني الذكاء الاصطناعي وضوابطه[15]	إطار وطني إرشادي/تنظيمي	حوكمة المعالجة الآلية للبيانات الشخصية (تفصيلها في DAF-ICT-02)

[1] نظام حماية البيانات الشخصية الصادر بالمرسوم الملكي رقم (م/19) بتاريخ 1443/2/9هـ (16 سبتمبر 2021م)، المعدل بالمرسوم الملكي رقم (م/148) بتاريخ 1444/9/5هـ (27 مارس 2023م)؛ نافذ من 14 سبتمبر 2023م، واكتمل الإلزام بانتهاء فترة السماح في 14 سبتمبر 2024م. الجهة المختصة: الهيئة السعودية للبيانات والذكاء الاصطناعي (سدايا).

[2] اللائحة التنفيذية لنظام حماية البيانات الشخصية الصادرة عن سدايا والنافذة من سبتمبر 2024م، وما تلاها من قواعد وأدلة إرشادية (سياسات الخصوصية، تقليل البيانات، إتلاف البيانات، الإفصاح، مشاركة البيانات، سجلات أنشطة المعالجة).

[3] لائحة نقل البيانات الشخصية خارج المملكة، الإصدار الثاني (أغسطس 2024م): تقييم مستوى الحماية (المادتان 3–4)، الضمانات المناسبة والبنود التعاقدية النموذجية (المادة 5)، حالات الاستثناء (المادتان 6–7)، تقييم المخاطر (المادة 8).

[4] دليل إجراءات حوادث اختراق البيانات الشخصية الصادر عن سدايا (أكتوبر 2024م): إشعار الجهة المختصة خلال (72) ساعة من العلم بالحادث عبر منصة الحوكمة الوطنية للبيانات، وإخطار أصحاب البيانات دون تأخير مفرط عند توقع ضرر يمسهم.

[5] قواعد السجل الوطني للمسؤولين (Controllers) داخل المملكة الصادرة عن سدايا (2024م): وجوب التسجيل في منصة الحوكمة الوطنية للبيانات لمن تقع في أي حالة من حالات التسجيل، وصحة الشهادة خمس سنوات مع تنبيه المسؤول قبل انتهائها بثلاثين يومًا.

[6] قواعد تعيين مسؤول حماية البيانات الشخصية الصادرة عن سدايا (2024م): حالات الوجوب الثلاث، وشروط شاغر الوظيفة من مؤهل وخبرة ونزاهة، وسجله عبر المنصة.

[7] البنود التعاقدية النموذجية لنقل البيانات الشخصية خارج المملكة (سبتمبر 2024م) وقواعد الربط الملزمة بين الكيانات التابعة، بصيغهما المعتمدتين من سدايا.

[8] مسودة تعديلات اللائحة التنفيذية لنظام حماية البيانات الشخصية المعروضة للاستطلاع العام على منصة (إستطلاع) من 6 أكتوبر 2026م حتى 5 نوفمبر 2026م، وأبرز مقترحاتها: اشتراط تخزين البيانات الشخصية داخل المملكة، وتوسيع نطاق إشعار الحادث، وإلزام المسجلين في السجل الوطني بتقديم سجلات أنشطة المعالجة، وتوثيق تعيين مسؤول حماية البيانات، ومهلة عشرين يوم عمل للرد على طلبات سدايا، وإلغاء المهلة الزمنية لتقديم الشكاوى، وتشديد ضوابط التسويق المباشر. تدخل التعديلات حيز النفاذ — إن اعتُمدت — بعد ستين يومًا من نشرها في الجريدة الرسمية.

[9] الضوابط الأساسية للأمن السيبراني الإصدار الثاني (ECC-2:2024) الصادر عن الهيئة الوطنية للأمن السيبراني: أربعة مجالات (الحوكمة، الحماية، المرونة، الأطراف الثالثة والحوسبة السحابية)، وثمانية وعشرون نطاقًا فرعيًا، ومائة ضابط رئيسي واثنان وتسعون ضابطًا فرعيًا. تُعد إلزامية للجهات الحكومية والمنشآت الواقعة ضمن البنية التحتية الحرجة، وتتبناها الجهة هنا خطًا أساسيًا استرشاديًا ملزمًا داخليًا.

[10] ضوابط أمن البيانات (Data Cybersecurity Controls — DCC) وضوابط أمن الحوسبة السحابية (Cloud Cybersecurity Controls — CCC) الصادرة عن الهيئة الوطنية للأمن السيبراني، وتُستخدم تفصيلًا عند تصميم ضوابط حماية قواعد البيانات والخدمات السحابية.

[11] المعيار الدولي ISO/IEC 27001:2022 لأنظمة إدارة أمن المعلومات، بضابطه المرجعي المحدث المؤلف من ثلاثة وتسعين ضابطًا في أربعة محاور (تنظيمية، بشرية، مادية، تقنية).

[12] نظام مكافحة الجرائم المعلوماتية الصادر بالمرسوم الملكي رقم (م/17) بتاريخ 1428/3/8هـ (27 مارس 2007م) وتعديلاته.

[13] نظام التعاملات الإلكترونية الصادر بالمرسوم الملكي رقم (م/18) بتاريخ 1428/3/8هـ وتعديلاته.

[14] إطار الأمن السيبراني الوطني الأمريكي NIST CSF 2.0 (فبراير 2024م) بمحاوره الستة: الحوكمة، التعرف على المخاطر، الحماية، الرصد والكشف، الاستجابة، التعافي.

[15] إطار تبني الذكاء الاصطناعي الصادر عن سدايا (نوفمبر 2025م) ضمن «عام الذكاء الاصطناعي 2026م»، بمحاوره: حوكمة البيانات، ومساءلة النماذج، والشفافية، والرقابة البشرية، وإدارة المخاطر؛ وتُفصَّل معالجاته في وثيقة DAF-ICT-02.

[16] سجلات أنشطة معالجة البيانات وفق المادة (31) من النظام ولائحته التنفيذية: تُحفظ أثناء المعالجة ولمدة خمس سنوات تبدأ من تاريخ إتمام النشاط، وتُقدَّم للجهة المختصة عند الطلب.

[17] المادة (36) من النظام: التحذير أو غرامة لا تتجاوز خمسة ملايين ريال، ويجوز مضاعفتها للمخالفة المتكررة مع النظر في العذر المقبول وفي الإبلاغ الذاتي. والمادة (35): السجن حتى سنتين و/أو غرامة حتى ثلاثة ملايين ريال لمن يفصح عن بيانات شخصية حساسة بقصد الإضرار بصاحبها أو تحقيق مصلحة خاصة. والمادة (40): التعويض عن الضرر.

المبحث 2: التعريفات والاصطلاحات

9. البيانات الشخصية: كل بيان — بأي صورة كانت — يتصل بشخص طبيعي محدد الهوية أو يمكن التعرف عليه، مثل: الاسم، رقم الهوية/الإقامة، الأرقام التعريفية، العناوين، أرقام الاتصال، الصور، البيانات المالية والصحية والمهنية، وما يكشف هويته من بيانات الاستخدام والموقع.
10. البيانات الحساسة: البيانات التي يتضمن معالجتها إلحاق ضرر بصاحبها، وتشمل — بحسب تعريف النظام المعدل: البيانات الصحية والنفسية، والبيانات الوراثية والبيومترية، وبيانات الائتمان (السجل الائتماني)، والبيانات المتعلقة بالجرائم والأحكام الأمنية، والبيانات المتعلقة بالانتماءات السياسية والدينية والقبلية/الإثنية، وبيانات الأشخاص المحرومين من الوالدين أو من أحدهما، وتخضع البيانات الصحية والائتمانية لأحكام خاصة في المادتين (23) و(24) من النظام[1].
11. معالجة البيانات: أي عملية إجرائية على البيانات الشخصية بأي وسيلة، تشمل الجمع والتسجيل والتخزين والتعديل والاسترجاع والاستخدام والإفصاح والنقل والإتلاف.
12. الجهة المختصة: الهيئة السعودية للبيانات والذكاء الاصطناعي (سدايا) أو من تفوضه، وتُمارس اختصاصاتها عبر منصة الحوكمة الوطنية للبيانات (dgp.sdaia.gov.sa).
13. المالك/المسؤول عن المعالجة (Controller): الجهة التي تحدد غرض معالجة البيانات ووسيلتها الأساسية؛ وهي في سياق هذه الوثيقة «الجهة» ما لم يُذكر خلاف ذلك.
14. المعالج (Processor): الشخص أو الجهة التي تعالج البيانات نيابة عن المالك وبتوجيهه، أو بالنيابة عنه وباسمه، مثل: مزودو الأنظمة السحابية، ومنصات جمع التبرعات، وشركات الاتصالات والتسويق المتعاقد معها.
15. المتلقي (Recipient): كل شخص أو جهة يُفصح له عن البيانات الشخصية (مانح، شريك، جهة حكومية، مُقاول)، سواء أكان طرفًا ثالثًا أم معالجًا.
16. الأطراف الثالثة (Third Party): كل جهة ليست صاحب البيانات ولا المعالج وأفراده في سياق المعالجة الموضوعة.
17. صاحب البيانات (Data Subject): الشخص الطبيعي الذي تتصل به البيانات: المستفيد، المتبرع، الكفيل، الموظف، المتطوع، المتدرب، الزائر، ممثل الشريك التعاقدي.
18. الموافقة (Consent): إذن صاحب البيانات — قبل بدء المعالجة — لمعالجة بياناته لغرض محدد، بصيغة واضحة ومحددة، مستقلة عن أي نص آخر، وقابلة للسحب بيسرٍ يساوي يسر منحها، ويُشترط كتابتها في الحالات التي تحددها اللائحة التنفيذية.
19. سحب الموافقة: إجراء يتمتع به صاحب البيانات في أي وقت، وله أثر مستقبلي (يتجه للمستقبل) ولا يُخل بقانونية المعالجة السابقة.
20. الأساس النظامي: السند الذي ترتكز إليه المعالجة (موافقة، أو اتفاق، أو التزام نظامي، أو مصلحة حيوية، أو مصلحة مشروعة موثقة التقييم، أو مهمة أمنية أو عدلية لجهة عامة).
21. تقييم المصلحة المشروعة (LIA): تقييم مكتوب يجرى قبل الاعتماد على المصلحة المشروعة أساسًا، يتضمن: أن لا يخالف الغرض نظامًا، وأن تتولى حقوق صاحب البيانات ميزانًا مع مصلحة الجهة فلا تُجحف، وأن تكون المعالجة للبيانات غير الحساسة، ويُحفظ التقييم وسط سجلات الامتثال[2].
22. سجل معالجة البيانات (ROPA): السجل الموثق لأنشطة معالجة البيانات بحدوده الدنيا المنصوصة في اللائحة التنفيذية (اسم المالك وبياناته، بيانات مسؤول الحماية، الأغراض، فئات البيانات والأشخاص، فترات الاحتفاظ، فئات المتلقين، النقل خارج المملكة وأساسه، وضوابط الأمن).

23. تقييم أثر حماية البيانات (DPIA): تقييم مسبق لعواقب معالجة معينة على خصوصية الأفراد وضوابط التخفيف، ويجب عند المعالجة المرجح أن يسبب ضررًا جسيمًا أو عند معالجة البيانات الحساسة أو اعتماد تقنيات ناشئة وفق مقترحات المسودة[8].
24. إشعار الخصوصية (Privacy Notice): إفصاح موجّه لصاحب البيانات قبل جمع بياناته أو لحظة جمعها بعناصره النظامية (الهوية، الأغراض، الأساس، الفئات، المتلقون، النقل، الاحتفاظ، الحقوق وطرق ممارستها).
25. حادثة اختراق البيانات الشخصية: كل حادث يؤدي — بشكل مقصود أو غير مقصود — إلى وصول غير مشروع إلى البيانات الشخصية أو إتلافها أو فقدانها أو تعديلها أو إفصاح عنها، أو وصول غير مشروع إليها بما يسبب ضررًا لصاحبها.
26. فترة الاحتفاظ: المدة التي تُحفظ فيها البيانات لتحقيق غرضها المحدد، وبعدها يجب إتلافها أو إخفاء هويتها، ما لم يوجد نص نظامي يوجب خلاف ذلك.
27. إتلاف البيانات: التخلص من البيانات بطريقة آمنة تمنع استرجاعها (محو آمن، تمزيق ورقي معتمد، إتلاف وسائط تخزين)، مع توثيق الإتلاف.
28. إخفاء الهوية (Anonymization): معالجة تجعل استحالة إعادة التعرف على صاحب البيانات بوسائل معقولة، فيخرج الناتج من نطاق تعريف البيانات الشخصية؛ ويُفرَّق عن الترميز (Pseudonymization) الذي يبقى قابلًا لإعادة التعرف ويبقى في النطاق.
29. أقل صلاحية (Least Privilege): منح المستخدم الحد الأدنى من الصلاحيات اللازمة لأداء مهامه فقط، ولأقصر مدة.
30. المصادقة متعددة العوامل (MFA): إثبات هوية المستخدم بعاملين أو أكثر من فئات مختلفة (شيء يعرفه، شيء يملكه، شيء يتميز به).
31. الأجهزة الشخصية (BYOD): استخدام الأجهزة المملوكة للأفراد في أعمال الجهة وفق ضوابط معتمدة.
32. اختبار الاختراق: محاكاة هجوم مصرّح بها مسبقًا لتقييم صمود الأنظمة وكشف الثغرات، ويجري بواسطة جهة مؤهلة وبنطاق وقواعد اشتباك موثقة.
33. النسخ الاحتياطي غير المتصل (Offline/Immutable Backup): نسخة محفوظة معزولة عن الشبكة أو غير قابلة للتعديل، تُستخدم ضد برمجيات الفدية.
34. الرمز المؤقت: الفترتان المعياريتان: RPO (نقطة الاسترداد: أقصى فقدان بيانات مسموح)، وRTO (زمن الاسترداد: أقصى مدة توقف مسموحة).
35. الحوسبة السحابية: تقديم خدمات تقنية (برمجيات، منصات، بنية تحتية) عبر الإنترنت بوصفها خدمة قابلة للتوسع عند الطلب.
36. المعالج من الباطن (Sub-processor): معالج يعهد إليه المعالج — بتفويض من المالك — بجزء من المعالجة.
37. البنود التعاقدية النموذجية (SCCs): صيغ تعاقدية معتمدة من الجهة المختصة تُبرم مع المتلقي خارج المملكة لضمان مستوى حماية مناسب.
38. قواعد الربط الملزمة (BCRs): قواعد ملزمة داخلية لدى مجموعة كيانات تكفل حماية البيانات المنقولة بينها خارج المملكة.
39. إدارة الهوية والوصول (**IAM**): منظومة إدارة هويات المستخدمين وصلاحياتهم ودورات حياتهم (إنشاء، تعديل، إيقاف، حذف).
40. سجل التدقيق (Audit Log): سجل زمني لأحداث الأنظمة الأمنية وعمليات الوصول والتغيير على البيانات.
41. إدارة الثغرات: دورة كشف وتصنيف ومعالجة وتحقق لثغرات الأنظمة، تشمل التحديثات البرمجية وإصلاح الإعدادات.
42. الامتثال القائم على إثبات الامتثال: الالتزام النظامي بأدلة موثقة تُظهر — عند الطلب — كيف تفي الجهة بالتزاماتها (سجلات، تقييمات، موافقات، محاضر، سجلات مراجعة).

المبحث 3: الحوكمة والأدوار والمسؤوليات

3.1 مجلس الإدارة أو مجلس الأمناء

43. يُقر المجلس هذه الوثيقة ويحدِّثها ويراقب فعالية منظومة حماية البيانات وأمن المعلومات، ويُدرج تقريرًا دوريًا (مرة على الأقل في السنة) عن: حالة الامتثال لنظام حماية البيانات الشخصية، وملخص الحوادث ودروسها، ونتائج اختبارات الاختراق والمراجعة الداخلية، ومستوى إنجاز خطة المعالجة.
44. يعتمد تعيين مسؤول حماية البيانات الشخصية وإنهاء تكليفه، ويقرر التسجيل في السجل الوطني للمسؤولين، ويوافق على المعالجات عالية الخطورة (معالجة بيانات حساسة على نطاق واسع، أو نقل بيانات خارج المملكة، أو اعتماد أنظمة سحابية جديدة) بناءً على توصية مكتوبة من المسؤول التنفيذي بعد رأي مسؤول حماية البيانات.
45. يوفر الموارد البشرية والمالية اللازمة للضوابط المتفق عليها في هذه الوثيقة، ويُدرج مخصصات الأمن السيبراني والتوعية في الموازنة السنوية وفق حقول التخصيص.
46. يتحمل المجلس والمسؤول التنفيذي المسؤولية النظامية والتأديبية عن الإخلال بالتزامات حماية البيانات في نطاق اختصاصاتهم، ومن ذلك ما تضبطه اللائحة التنفيذية لنظام الجمعيات والمؤسسات الأهلية من جزاءات.

(DAF-POL-ICT-01-04) لا يبدأ تشغيل أي نظام معلوماتي جديد يعالج بيانات شخصية، ولا يُطلق أي برنامج يوسع نطاق البيانات الحساسة المعالجة، إلا بعد موافقة المجلس أو من يفوضه وفق مصفوفة الصلاحيات في DAF-GOV-05، مرفقة بتقييم أثر حماية البيانات متى وجبت حالته.

3.2 المسؤول التنفيذي (الأمين العام/الرئيس التنفيذي)

47. يشرف على تنفيذ هذه الوثيقة ويحوّلها إلى إجراءات تشغيلية معتمدة، ويوفر الكفاءات والأدوات، ويعتمد خطط المعالجة للملاحظات والثغرات.

48. يقرر — بناءً على رأي مسؤول حماية البيانات — مسألتي التسجيل في السجل الوطني للمسؤولين، وتعيين مسؤول حماية البيانات، ويوقف أي معالجة يرى أنها تخلّ بالنظام إلى أن تُعالج أسبابها.

49. يمثّل الجهة أمام الجهة المختصة وسائر الجهات الرقابية فيما يتصل بحماية البيانات، ويوقّع الإشعارات والإقرارات النظامية أو يفوض من يوقعها بقرار مكتوب.

50. يضمن تضمين التزامات حماية البيانات وأمن المعلومات في عقود التوظيف والتطوع والتعاقد الخارجي، وفي شروط التعامل مع المنصات الإلكترونية.

(DAF-POL-ICT-01-05) يلتزم المسؤول التنفيذي بأن تستجيب الجهة لطلبات الجهة المختصة خلال المهلة النظامية المعمول بها، وأن تُحدَّث هذه المهلة في الإجراءات فور اعتماد مقترحات المسودة الجاري استطلاعها (عشرون يوم عمل اعتبارًا من استلام الطلب، مع جواز طلب التمديد بمبرر مقبول لدى الجهة المختصة)[8].

3.3 مسؤول حماية البيانات الشخصية (DPO)

51. حالات التعيين: تُقدّر الجهة وضعها بقرار مكتوب مسبب ضد حالات الوجوب الثلاثة في قواعد سدايا: (أ) أن تكون الجهة كيانًا عامًا يقدم خدمات تتضمن معالجة بيانات شخصية على نطاق واسع؛ (ب) أن يشمل نشاطها الأساسي مراقبة منتظمة ومنهجية لأصحاب البيانات على نطاق واسع؛ (ج) أن يشمل نشاطها الأساسي معالجة بيانات شخصية حساسة على نطاق واسع[6]. وعمليًا، فإن الجهات غير الربحية التي تدير سجلات مستفيدين صحية أو إغاثية واسعة تستوفي غالبًا حالة (ج) أو حالة (ب)، وعليها التعيين وتسجيل بيانات المسؤول عبر منصة الحوكمة الوطنية للبيانات وتحديثها عند أي تغيّر.

52. الشروط: أن يمتلك مؤهلًا علميًا وخبرة في حماية البيانات وفهمًا بإدارة المخاطر، وأن يكون سجل نظافته خاليًا من إدانات في جرائم مخلة بالشرف أو الأمانة، ويجوز أن يكون موظفًا داخليًا أو متعاقدًا خارجيًا، بشرط ضمان استقلاليته وعدم تضارب أدواره (فلا يُعين لمنصب يقرر فيه بنفسه غرض المعالجة ووسيلتها ثم يراقب قراره).

53. المهام: الإشراف على الالتزام بالنظام ولائحتها، والتواصل مع الجهة المختصة ومع أصحاب البيانات، وتقديم الرأي المسبب في تقييمات الأثر والمصالح المشروعة، والمشاركة في إدارة الحوادث وإعداد الإشعارات، والتوعية، والإبلاغ الدوري للمجلس والمسؤول التنفيذي، والاحتفاظ بسجل التوصيات والقرارات المتعلقة بحماية البيانات.

54. الاستقلالية والحماية: لا يجوز إنهاء تكليفه أو تقليص صلاحياته تعسفيًا، ولا يجوز محاسبته على أداء مهامه الرقابية بحسن نية، ويُنقل إليه مباشرةً أي إخطار بحادثة أو طلب رقابي.

(DAF-POL-ICT-01-06) يُعيَّن مسؤول حماية البيانات بقرار مكتوب يحدد اختصاصاته وتبعيته، وتُسجَّل بياناته في منصة الحوكمة الوطنية للبيانات، ويُحدَّث التسجيل فور أي تغيير؛ ويُراجَع القرار سنويًا لاستيفاء شروط الحالة والاستمرار.

3.4 مالك الأصل ومالك النظام

55. يُحدَّد لكل نظام معلوماتي وبنية بيانات «مالك» من الإدارات التشغيلية (مالك نظام إدارة المستفيدين: إدارة البرامج؛ مالك نظام شؤون الموظفين: الموارد البشرية؛ مالك منصة التبرعات: إدارة التطوير والشراكات، وهكذا). ويشمل نطاقه: تحديد الغرض والأساس النظامي للمعالجة في نظامه، واعتماد صلاحيات الوصول للبيانات في نطاقه، واقتراح فترات الاحتفاظ، والتصديق على جودة بياناته، ومراجعة استخداماته الدورية.

56. المتلقي: يُحدَّد مسؤول داخلي عن كل فئة من فئات المتلقين الخارجيين (المانحون، الجهات الحكومية، الشركاء المنفذون) يضمن أن المشاركة موثقة في سجل المشاركات، وأن الأساس النظامي قائم، وأن المعالجة بعد المشاركة تلتزم بالغرض المتفق عليه.

(DAF-POL-ICT-01-07) لا يجوز تشغيل نظام يعالج بيانات شخصية دون مالك معلن له في سجل الأنظمة، ولا مشاركة بيانات مع متلقٍّ خارجي دون مسؤول داخلي معلن يوقع على قائمة المشاركة (النموذج 19.4).

3.5 منسق الأمن السيبراني/تقنية المعلومات

57. يدير الضوابط التقنية اليومية: إدارة الهويات والصلاحيات، التحديثات والنسخ الاحتياطي، مراقبة الأمن، إدارة الثغرات، استجابة الحوادث تقنيًا، واختبارات الاستعادة.
58. يُعد خطة الأمن السيبراني السنوية مبنية على خط الأساس ECC-2:2024 ومعيار ISO/IEC 27001:2022 متناسبة مع حجم الجهة، ويطلع المسؤول التنفيذي والمجلس عليها.
59. يقود الاستجابة التقنية للحوادث بالتنسيق مع مسؤول حماية البيانات (الجانب التنظيمي والإخطاري) وفق المبحث 12.

(DAF-POL-ICT-01-08) يُسمّى منسق الأمن السيبراني بقرار مكتوب من المسؤول التنفيذي، وتُحدَّد اختصاصاته وصلاحياته الطارئة (إيقاف أنظمة، عزل أجهزة، تدوير أسرار)، ويُراعى في التسمية مبدأ فصل المهام بحيث لا يجمع من ينفذ الضوابط وحده سلطة مراجعتها وحيدًا.

3.6 الموظفون والمتطوعون والمستخدمون

60. يوقّع المستخدم قبل منحه أي صلاحية على «إقرار الاستخدام المقبول وسرية البيانات» الذي يتضمن: استخدام بيانات الجهة لأغراض العمل فقط، عدم مشاركة بيانات الدخول، التزام ضوابط الأجهزة الشخصية، والإبلاغ الفوري عن أي مؤشر اختراق أو فقدان جهاز.
61. يتحمل كل مستخدم مسؤولية أنشطته على حسابه؛ فلا يعير بيانات دخوله لأي شخص كان، وأي نشاط يصدر من حسابه يُنسب إليه ما لم يُثبت اختراقًا أُبلغ عنه فورًا.
62. يُدرَّب المستخدم عند التعيين (وجوبًا) ودوريًا (سنويًا على الأقل) وفق المبحث 14، ويُسحب وصوله فور انتهاء علاقته أو انتقاله وفق دورة حياة الصلاحيات.

(DAF-POL-ICT-01-09) يحظر على أي موظف أو متطوع: نسخ قواعد بيانات الجهة أو تصديرها إلى أجهزة أو حسابات شخصية، أو فتح رسائل وروابط مشبوهة، أو تثبيت برامج غير معتمدة، أو إفشاء بيانات المستفيدين والمتبرعين لغير المخولين تحت أي مبرر؛ ويُعدّ ذلك مخالفة جسيمة تستوجب المساءلة وفق وثيقة DAF-HR-04.

3.7 المعالجون والمقاولون

(DAF-POL-ICT-01-10) يُلزم كل معالج أو مقاول يتصل ببيانات الجهة ببنود تعاقدية تتوافق مع المبحث 9، ويجتاز قائمة الفحص (19.6) قبل التعاقد، ويلتزم بضوابط أمن المعلومات الموثقة عند منحه أي وصول.

3.8 مصفوفة الأدوار المختصرة (RACI)

النشاط	المجلس	المسؤول التنفيذي	مسؤول حماية البيانات	منسق الأمن/IT	مالك النظام	المستخدم
اعتماد الوثيقة والتحديثات	A	R	C	C	C	I
التسجيل في السجل الوطني	I	A	R	C	C	—
تعيين مسؤول حماية البيانات	A	R	C	I	I	—
إعداد إشعارات الخصوصية	—	A	R	C	C	I
إدارة الصلاحيات والمراجعات	I	A	C	R	C	I
الاستجابة للحوادث	I	A	R	R	C	I
إشعار سدايا	—	A	R	C	C	—

النشاط	المجلس	المسؤول التنفيذي	مسؤول حماية البيانات	منسق الأمن/IT	مالك النظام	المستخدم
خلال 72 ساعة						
تقييمات الأثر والمصلحة المشروعة	I	A	R	C	C	—
النقل عبر الحدود	A	R	R	C	C	—
اختبار الاختراق والتدقيق	A	R	C	R	C	—
التدريب والتوعية	I	A	R	C	C	R

(حرف دلالة: R منفِّذ، A معتمد/مسؤول، C يُستشار، I يُطَّلع.)

المبحث 4: تصنيف البيانات والأصول

4.1 مستويات التصنيف

(DAF-POL-ICT-01-11) تُصنَّف بيانات الجهة إلى أربعة مستويات تحدد درجة الضوابط المطبقة عليها:

المستوى	التعريف	أمثلة في الجهة	أدنى الضوابط
عام (Public)	بيانات النشر الرسمي المعتمد	الموقع الإلكتروني، الأخبار والتقارير السنوية المعتمدة	ضوابط النشر الاعتيادية
داخلي (Internal)	بيانات العمل غير المصرح نشرها	موازنات داخلية، محاضر اجتماعات، بيانات تشغيلية	وصول بالصلاحيات، منع النشر الخارجي
سرّي (Confidential)	بيانات شخصية عادية وبيانات مالية تعاقدية	بيانات المتبرعين والموظفين والمتطوعين، العقود	تشفير أثناء النقل والتخزين، سجل وصول، منع التصدير غير المصرح
سري للغاية/حساس (Restricted/Sensitive)	بيانات حساسة نظامًا أو بيانات يتوقع ضررها الجسيم	بيانات المستفيدين الصحية والإغاثية، الأسرار المصرفية للحسابات، بيانات الأحداث الأمنية	تشفير قوي، وصول مقيد وموثق ومبرر، MFA إلزامي، عزل، رصد مستمر، ممنوع التخزين الشخصي

4.2 قواعد التصنيف

63. تُصنَّف البيانات عند إنشائها أو استلامها وفق جدول التصنيف، ويستند التصنيف إلى أعلى درجة بين مكونات المجموعة (فمجموعة ملفات مستفيد تجمع بيانات عادية وحساسة تُصنَّف بأعلى درجة).

64. يملك مسؤول حماية البيانات حسم الخلاف في التصنيف، ويعتمد المجلس قائمة فئات البيانات المحدثة سنويًا.

65. يُراعى في التصنيف تعريف البيانات الحساسة في النظام المعدل، وتُمنع معالجة أي فئة حساسة إلا بأساس نظامي مستقل ومبرر موثق (المبحث 5.3) وبضوابط مشددة[1].

4.3 جرد الأصول والبيانات

(DAF-POL-ICT-01-12) تحتفظ الجهة بجرد محدث للأصول المعلوماتية (أجهزة، أنظمة، خدمات سحابية، حسابات، قواعد بيانات، تراخيص) يتضمن: المالك، الموقع، مستوى التصنيف، الجهة المشغلة (داخلي/سحابي/مقاول)، وآخر مراجعة. وتُحدَّث السجلات عند كل إضافة أو إيقاف، ويُراجع الجرد كل ستة أشهر على الأقل.

4.4 وسم وتسمية البيانات

66. تُوسم المستندات والملفات الإلكترونية بمستوى تصنيفها (ترويسة «سري — بيانات شخصية» على القوالب ذات الصلة)، وتُخزَّن البيانات السرية للغاية في مستودعات معزولة بصلاحيات مخصصة.

67. لا يجوز نقل بيانات بمستوى «سري» أو أعلى إلى بريد شخصي أو أجهزة غير معتمدة أو خدمات سحابية عامة مجانية، ولا طباعتها إلا للضرورة وتحت الحفظ والإتلاف المتوثق.

(DAF-POL-ICT-01-13) تُحدَّد تويسات التصنيف المعتمدة وتُدمج في قوالب الجهة الرسمية، ويتحمل مالك كل نظام إظهار مستوى تصنيف بياناته في واجهاته وتقاريره، ويُحظر إرسال أو تخزين أي ملف سرّي فأعلى دون وسمه.

المبحث 5: دورة حياة البيانات الشخصية

(DAF-POL-ICT-01-14) تُدار البيانات الشخصية في الجهة كدورة حياة كاملة مترابطة: جمع مشروع ← تصنيف وتوثيق ← غرض محدد وأساس نظامي ← إشعار صاحب البيانات ← تقليل ودقة ← استخدام مقيد بالغرض ← حقوق الأفراد ← احتفاظ محدد المدة ← إتلاف آمن. ولا يجوز الانتقال بين مرحلتين بإخلال التزام المرحلة السابقة.

5.1 الجمع ومصدره

68. تجمع الجهة البيانات من صاحبها مباشرة كلما أمكن؛ وعند الجمع من مصدر ثالث (قوائم مشاريع مشتركة، شركاء، الجهات الحكومية) تلتزم بأحكام النظام المتعلقة بالجمع من أطراف أخرى، وتتحقق من مشروعية مصدر البيانات، وتُبلَّغ صاحب البيانات وفق ما يقتضيه النظام[1].

69. يقتصر الجمع على البيانات اللازمة لغرض معلن؛ ويحظر الجمع السري أو الخادع أو التسجيل غير المعلن (كاميرات المراقبة تُعلَّق لافتاتها، والتسجيلات الصوتية للمكالمات تُباشر بإخطار مسبق).

70. بيانات الأطفال: لا تُعالج بيانات الطفل إلا بضوابط المصلحة الفضلى، وبموافقة ولي الأمر أو ممثله النظامي متى اشترط النظام الموافقة، ويستلزم النظام التحقق من هوية الولي في حالات معينة[1]. ويُمنع استخدام بيانات الأطفال في أي معالجة تسويقية غير مستوفية للضوابط.

71. تُنفَّذ آلية تحقق من هوية صاحب البيانات عند التعامل مع طلبات تخصه (المبحث 5.7) تتناسب مع حساسية البيانات وخطورة الطلب.

5.2 الغرض وتحديده

(DAF-POL-ICT-01-15) لا تُجمع بيانات ولأكثر من غرض محدد ومعلن مسبقًا يمكن فهمه من إشعار الخصوصية؛ ولا يجوز لاحقًا معالجتها لغرض جديد غير متوافق مع الغرض الأصلي إلا بأساس نظامي مستقل أو موافقة جديدة، ويُحدَّث السجل وسياسة الخصوصية عند أي توسع في الأغراض[1].

5.3 الأسس النظامية للمعالجة

(DAF-POL-ICT-01-16) لكل نشاط معالجة أساس نظامي موثق في سجل المعالجة قبل بدئه، ولا يجوز الاعتماد على أكثر من أساس وهمي لنشاط واحد؛ وتكون الأولوية النظامية كما يلي:

الأساس	متى يُستخدم في الجهة غير الربحية	ضوابطه الخاصة
الموافقة	التسويق المباشر، نشر الصور والقصص الإنسانية، مشاركة البيانات الطوعية، أي معالجة اختيارية	أن تكون صريحة ومحددة ومستقلة وقابلة للسحب بيسر؛ وتُحفظ أدلتها
اتفاق يلتزم به صاحب البيانات	التبرع بخصم شهري، عضوية، أو تسجيل في برنامج يتضمن التزامات متبادلة	أن تكون المعالجة ضرورية للاتفاق لا مريحة فقط
التزام نظامي	الاحتفاظ بالسجلات المالية والضريبية،	الاقتصار على ما يوجبه النص

الأساس	متى يُستخدم في الجهة غير الربحية	ضوابطه الخاصة
	التقارير للجهات المختصة، مكافحة غسل الأموال (DAF-CMP-01)	
المصلحة الحيوية	حالات طوارئ إنسانية تستدعي حماية حياة شخص أو سلامته	أن تتعذر موافقة مسبقة وتُستكمل فور الإمكان
المصلحة المشروعة	تحسين الخدمات الداخلية، أمن الشبكات، منع الاحتيال، إدارة علاقات المتبرعين غير التسويقية	تقييم LIA مسبق مكتوب، لا تصلح للبيانات الحساسة[2]
مهمة أمنية أو عدلية لجهة عامة	الاستجابة لطلبات الجهات المختصة نظامًا	موثقة، وبأقل بيانات، وبقرار من المسؤول التنفيذي

ويُستثنى من الموافقة في حالات نظامية محددة أخرى (الأبحاث والدراسات بضوابط)، ولا يُبنى أي نشاط على الاستثناءات إلا بقرار مسؤول حماية البيانات مسبب.

5.4 إشعار الخصوصية

(DAF-POL-ICT-01-17) تُعِدّ الجهة سياسة خصوصية منشورة على موقعها ومنصاتها، وإشعارات خصوصية لكل قناة جمع، تتضمن كحد أدنى: هوية الجهة وبيانات التواصل، وبيانات مسؤول حماية البيانات، والأغراض والأسس النظامية، وفئات البيانات، وفئات المتلقين، والنقل خارج المملكة إن وُجد، وفترات الاحتفاظ، وحقوق صاحب البيانات وطرق ممارستها، ووسائل التواصل مع الجهة المختصة[2]. ويلتزم الإشعار بأن يكون بلغة واضحة مبسطة مفهومة غير مبهمة، وتُعرض موافقات التسويق بصورة مميزة منفصلة، وتُراجع السياسة والإشعارات عند كل تغيير جوهري.

5.5 التقليل واقتصاد الجمع

(DAF-POL-ICT-01-18) تقتصر الجهة في جمعها على الحد الأدنى من البيانات اللازم لتحقيق الغرض المعلن فعلًا (تقليل البيانات)، وتستخدم — حيث يفي بالغرض — بيانات مجمعة أو مرمزة أو مُخفى الهوية، ولا تجمع بيانات «احتياطًا لربما احتجناها»، وتراجع نماذج الجمع دوريًا لإسقاط أي حقل لا غنى عنه[2].

5.6 جودة البيانات ودقتها

(DAF-POL-ICT-01-19) تتخذ الجهة إجراءات عملية لضمان أن بياناتها الشخصية صحيحة وكاملة ومحدثة وصادقة في مصدرها قبل الاعتماد عليها، وخاصة البيانات المستخدمة في قرارات تمس الأفراد (استحقاق المساعدات)، وتمكّن أصحابها من تصحيحها وفق المبحث 5.7؛ وتُراجع سجلات المستفيدين ربع سنويًا على الأقل لإزالة المكرر والمطفأ.

5.7 حقوق الأفراد (صاحب البيانات)

(DAF-POL-ICT-01-20) تكفل الجهة لصاحب البيانات ممارسة حقوقه النظامية دون عوائق مصطنعة، وتديرها عبر قناة موحدة (بريد/نموذج إلكتروني/هاتف معلن):

الحق	مضمونه	مهلة الاستجابة	ملاحظات
العلم والاطلاع	إبلاغه بالأساس والغرض والجهات	لحظة الجمع بإشعار الخصوصية	—
الوصول	الاطلاع على بياناته	30 يومًا قابلة للتمديد 30 يومًا بمبرر مكتوب مع إخطاره[2]	بعد التحقق من هويته
الحصول على نسخة	نسخة بصيغة واضحة مقروءة	ضمن المهلة ذاتها	بوسيلة آمنة

الحق	مضمونه	مهلة الاستجابة	ملاحظات
التصحيح والإكمال والتحديث	تصويب بياناته	ضمن المهلة ذاتها	مع إخطار من لديهم نسخًا من المتلقين عند الاقتضاء
الإتلاف	طلب إتلاف بياناته	ضمن المهلة ذاتها	ما لم يوجد التزام نظامي بالاحتفاظ (يُخبر بوجوده)
سحب الموافقة	وقف المعالجة المبنية عليها	فوري عمليًا	بوسيلة يسيرة كوسيلة المنح
الاعتراض والمراجعة البشرية	عند القرارات الآلية المؤثرة	ضمن المهلة ذاتها	وفق المبحث 7.4
الشكوى	التظلم لدى الجهة المختصة	—	عبر قنوات سدايا (المهلة النظامية الحالية 90 يومًا من العلم بالمخالفة، وتتابع الجهة مقترح إلغائها في المسودة)[8]

إجراءات التعامل مع طلبات الأفراد: (1) استلام وتسجيل الطلب وإصدار رقم مرجعي؛ (2) تحقق من الهوية بما يتناسب مع خطورة البيانات دون مطالبة ببيانات زائدة؛ (3) استيفاء الطلب من مالكي الأنظمة المعنيين؛ (4) الرد المكتوب المسبب؛ (5) توثيق الطلب والرد في السجل (نموذج 19.5) مدة لا تقل عن سنة. ويجوز رفض الطلب — بقرار مسؤول حماية البيانات مكتوبًا — في الحدود النظامية (تعارض التزام نظامي، إخلال بأمن المملكة أو حقوق الغير، استحالة التحقق، طلبات متكررة مجحفة)، مع إخطار صاحب البيانات بحقه في الشكوى.

5.8 فترات الاحتفاظ والإتلاف

(DAF-POL-ICT-01-21) تُحدَّد فترة احتفاظ لكل فئة بيانات في سجل المعالجة، لا تتجاوز تحقيق الغرض والالتزامات النظامية، وتعتمد الجهة جدولًا استرشاديًا يحدَّث وفق حقول التخصيص:

فئة البيانات	مدة الاحتفاظ الاسترشادية	المبرر
بيانات المتبرعين والمحاسبية	حسب الالتزامات النظامية للسجلات المالية (تصل إلى عشر سنوات وفق الأنظمة الضريبية والمحاسبية)	التزام نظامي (DAF-FIN-01)
بيانات المستفيدين من البرامج	مدة البرنامج + فترة تقييم أثر لا تتجاوز [▸ ثلاث سنوات] ما لم يوجد مانع نظامي	الغرض + المصلحة المشروعة الموثقة
بيانات المتطوعين	مدة التطوع + [▸ سنتان]	إدارة البرنامج والإفصاح للجهات عند الاقتضاء
سجلات التوظيف غير المقبول	[▸ سنة واحدة] من انتهاء التقييم	تقليل البيانات
طلبات أصحاب البيانات وسجلات الموافقات	[▸ خمس سنوات] من اكتمال المعالجة	إثبات الامتثال[16]
مراسلات التسويق والموافقات وسحبها	[▸ خمس سنوات]	إثبات الامتثال ونزع الموافقة[2]
كاميرات المراقبة	[▸ تسعون يومًا] ما لم يوجد سبب نظامي	تقليل البيانات
سجلات الأمن والتدقيق	[▸ سنة واحدة] على الأقل، وسجلات الدخول للأنظمة الحساسة [▸ سنة]	كشف التحقيقات[9]

(DAF-POL-ICT-01-22) عند انتهاء فترة الاحتفاظ، أو سحب الموافقة متى كان هو الأساس ولا يوجد أساس بديل، تُتلف البيانات آمنًا خلال [▸ ستين يومًا] بأسلوب يمنع الاسترجاع (محو آمن للإلكتروني وفق معايير مقبولة صناعيًا، وتمزيق معتمد للورقي عند تجاوز حجم معين مع شهادة إتلاف)، وتُتلف النسخ الاحتياطية ضمن دورة النسخ التالية ما لم تقتضِ الضرورة التخزين البارد معزولًا، ويُوثَّق كل إتلاف بمحضر يحدد: الفئة والكمية والوسيلة والتاريخ والمسؤول وطريقة التحقق. ويجوز بدل الإتلاف إخفاء الهوية متى أُتي بمعايير تمنع إعادة التعرف بوسائل معقولة.

المبحث 6: سجل معالجة البيانات (ROPA)

6.1 الالتزام والنطاق

(DAF-POL-ICT-01-23) تحتفظ الجهة بسجل مكتوب لأنشطة معالجة البيانات الشخصية يشمل جميع أنظمتها وبرامجها وقنواتها، ويكون جاهزًا للعرض على الجهة المختصة عند الطلب[16]. ويعتبر السجل قلب نظام الامتثال؛ فلا يُعترف بأي نشاط معالجة غير مقيد فيه. ويُحفظ السجل أثناء استمرار المعالجة ولمدة خمس سنوات تبدأ من تاريخ إتمام النشاط، ويضمن المالك تحديثه ودقة محتواه.

6.2 الحد الأدنى لمحتوى السجل

يشتمل سجل كل نشاط معالجة — وفق اللائحة التنفيذية — على العناصر الآتية (النموذج الكامل 19.2):

72. اسم الجهة وبيانات التواصل (وللوفاء بهذا القالب تكفي بيانات الجهة العامة المعلنة).
73. بيانات مسؤول حماية البيانات متى وجب تعيينه.
74. أغراض المعالجة (محددة وقابلة للفهم لا عامة).
75. وصف فئات أصحاب البيانات (متبرعون، مستفيدون، موظفون...).
76. وصف فئات البيانات المشمولة، مع تمييز البيانات الحساسة تمييزًا واضحًا.
77. فئات المتلقين (داخليًا وخارجيًا) ممن يُفصح لهم عن البيانات.
78. النقل خارج المملكة أو الإفصاح لطرف خارجها: الوصف، والأساس النظامي، وهوية المتلقي، والضمانات المعتمدة.
79. فترات الاحتفاظ لكل فئة.
80. وصف الإجراءات والتدابير التنظيمية والفنية والإدارية الضابطة لأمن البيانات.
81. الأساس النظامي لكل غرض معالجة، ومرجع الموافقة أو التقييم المرتبط به.

6.3 الملكية والتحديث

- المالك العام للسجل: مسؤول حماية البيانات؛ ومالكو الأنظمة مسؤولون عن صحة بنود أنشطتهم.
- يُحدَّث السجل عند كل حدث مؤثر (إطلاق نظام، تغيير غرض، إضافة متلقٍ، بدء نقل خارجي، تغيير فترة احتفاظ)، ويُراجع كاملًا مرة في السنة على الأقل بمحضر مراجعة.
- يُوثَّق في السجل تاريخ آخر تحديث لكل بنوده.

6.4 التسجيل في السجل الوطني للمسؤولين

(DAF-POL-ICT-01-24) تُقيّم الجهة — بقرار مكتوب سنوي — وقوعها في حالات وجوب التسجيل في السجل الوطني للمسؤولين عبر منصة الحوكمة الوطنية للبيانات[5]

حالة التسجيل	انطباقها النموذجي على الجهات غير الربحية
كيان عام	غالبًا لا تنطبق على الجمعيات والمؤسسات الأهلية الخاصة، وتنطبق على الجهات ذات الصفة العامة — تُقيَّم حالة الجهة قانونيًا
النشاط الأساسي قائم على معالجة البيانات الشخصية	تنطبق على كثير من الجهات التي تدير سجلات مستفيدين ومستفيدات واسعة عبر أنظمة معلوماتية
نقل البيانات خارج المملكة أو الإفصاح لطرف خارجها	تنطبق فورًا عند أي نقل (منصات دفع دولية، شركاء خارجيون، أنظمة سحابية خارجية)

حالة التسجيل	انطباقها النموذجي على الجهات غير الربحية
معالجة بيانات حساسة	تنطبق على الجهات التي تعالج بيانات صحية أو إغاثية حساسة
معالجة بيانات أشخاص فاقدي الأهلية كليًا أو جزئيًا	حسب طبيعة البرامج

فإذا تحققت حالة واحدة وجب التسجيل خلال [▸ تسعين يومًا] من تحققها، وتُحدَّث بيانات التسجيل عند أي تغيير، وشهادة التسجيل صالحة خمس سنوات وتُجدَّد قبل انتهائها بثلاثين يومًا[5]؛ وتُقدَّم للجهة المختصة نسخة من سجل المعالجة متى طُلب أو متى ألزمت التعديلات المقترحة بإرفاقه بالتسجيل[8]، وتُتابع الجهة مواءمة إجراءاتها مع الصيغة النهائية للتعديلات فور اعتمادها.

المبحث 7: تقييم أثر حماية البيانات (DPIA) والمصالح المشروعة والقرارات الآلية

7.1 متى يُجرى تقييم الأثر

(DAF-POL-ICT-01-25) يُجرى تقييم أثر حماية البيانات قبل بدء أي معالجة جديدة يرجح أن تسبب ضررًا جسيمًا لخصوصية الأفراد، وعلى الأخص عند: (1) معالجة بيانات حساسة؛ (2) معالجة بيانات الأطفال أو الأشخاص فاقدي الأهلية؛ (3) المراقبة المنتظمة والمنهجية على نطاق واسع؛ (4) اعتماد تقنيات ناشئة (ذكاء اصطناعي، تحليلات تنبؤية، أدوات التعرف على الوجوه)[8]؛ (5) أي نظام جديد للجهة يعالج بيانات مستفيدين على نطاق واسع. وتُحدَّث التقييمات عند تغيير جوهري في المعالجة.

7.2 خطوات تقييم الأثر

82. وصف المعالجة وأنظمتها وقنواتها وسير بياناتها.
83. تقييم الضرورة والتناسب: هل تفي المعالجة بالغرض بأقل بيانات وأقل وسيلة تدخل في الخصوصية؟
84. تحليل المخاطر على حقوق أصحاب البيانات (تسرب، تمييز، قرارات خاطئة، مراقبة مفرطة).
85. تحديد تدابير التخفيف (تقليل، تشفير، رقابة بشرية، تجزئة الصلاحيات، دورات احتفاظ قصيرة).
86. قرار مكتوب: المضي مع التدابير، أو تعديل التصميم، أو عدم المضي، يعتمد من المسؤول التنفيذي بعد رأي مسؤول حماية البيانات، ويُرفق التقييم بسجل المعالجة، ويُقدَّم نسخة منه لكل معالج يشترك في النشاط[2].

7.3 تقييم المصلحة المشروعة (LIA)

(DAF-POL-ICT-01-26) لا يُعتمد أساس المصلحة المشروعة إلا بورقة تقييم محفوظة تثبت: أن الغرض لا يخالف نظامًا؛ وأن ميزان المصالح لا يجحف بحقوق الأفراد (تُوثَّق المنافع مقابل التأثيرات وتدابير التخفيف)؛ وأن المعالجة لا تشمل بيانات حساسة[2]. ويُراجع التقييم دوريًا، ويتوقف الاعتماد عليه إذا تبدلت الظروف أو طرأ نظام أدق.

7.4 المعالجة الآلية واتخاذ القرارات

(DAF-POL-ICT-01-27) عند الاعتماد على معالجة آلية (بما فيها الأدوات الذكية) في قرارات مؤثرة في الأفراد — كفرز طلبات الاستحقاق أو التصنيف الآلي للمستفيدين — تلتزم الجهة بأن: تُبلِّغ الفرد بذلك في إشعار الخصوصية، ولا تبني القرار النهائي اعتمادًا كليًا على المعالجة الآلية فيما يمس حقوقه المصيرية، وتوفر قناة طلب تدخل بشري مراجع واعتراض وإعادة نظر، وتوثق منطق القرار ومؤشراته وحدود دقته، وأن تلتقي معالجاتها في هذا الشأن مع إطار حوكمة الذكاء الاصطناعي الوطني وأحكام DAF-ICT-02[15]. وتُجرى لهذه الأنظمة تقييمات أثر دورية أعمق من المعتاد.

المبحث 8: الضوابط التقنية لأمن البيانات والأنظمة

(DAF-POL-ICT-01-28) تبني الجهة دفاعاتها على مبدأ الدفاع المتعمق (Defense in Depth) وخط الأساس في الضوابط الأساسية للأمن السيبراني ECC-2:2024[9] وضوابط معيار ISO/IEC 27001:2022[11]، على نحو متناسب مع حجم الجهة ومخاطرها؛ فما عُجز عنه بضعف الموارد عوّض عنه بترتيب الأولويات: حماية البيانات الحساسة والحسابات المميزة والنسخ الاحتياطية أولًا.

8.1 إدارة الهوية والصلاحيات

(DAF-POL-ICT-01-29) تُدار الهويات والصلاحيات وفق القواعد الآتية:

87. حساب لكل فرد: لا حسابات مشتركة إطلاقًا؛ ويجوز حساب خدمة (Service Account) بمالك معلن ومراقبة مشددة.
88. أقل صلاحية: تُمنح الصلاحيات على قاعدة الحد الأدنى الضروري لدور وظيفي معلن (RBAC)، وتُمنع صلاحيات المدير العامة للاستخدام اليومي.
89. فصل المهام: يفصل بين منفذ العملية ومراجعها ومُقرّها في العمليات الحساسة (المدفوعات، صلاحيات الأنظمة، التصدير) بما يوافق مصفوفة الصلاحيات DAF-GOV-05.
90. دورة حياة الحسابات: إنشاء الحسابات بموافقة مالك النظام ومسؤوله، وتعديلها عند تحوّل الموظف خلال [▸ خمسة أيام عمل]، وإيقافها فورًا عند انتهاء الخدمة وقبل ساعة انتهاء اليوم الأخير عمليًا، وحذفها خلال [▸ ثلاثين يومًا] بعد التحقق من عدم الحاجة لأرشفتها.
91. المصادقة متعددة العوامل (MFA): تُفعَّل إلزاميًا على: البريد الإلكتروني، والحسابات الإدارية والمصرفية والمالية، وأنظمة المستفيدين، والوصول عن بُعد، ومنصات جمع التبرعات الإدارية، وأي نظام مصنف «سري» فأعلى[9]. ويُفضَّل تعميمها على جميع المستخدمين.
92. الحسابات المميزة: حسابات المديرين (Administrators) تُسمَّى وتحصر وتُراقب، وتُستخدم لمهام الإدارة فقط لا للتصفح، وتُغلق جلساتها تلقائيًا، ويُحظر تخزين بيانات دخولها في نصوص واضحة.
93. كلمات المرور: تُفرض سياسة تقنية معتمدة (طول لا يقل عن [▸ اثني عشر] حرفًا للحسابات المميزة و[▸ عشرة] لغيرها، وتعقيد، ومنع إعادة الاستخدام، ومنع القواميس الشائعة)، وتُدار عبر مدير كلمات مرور معتمد مؤسسيًا.
94. الوصول عن بُعد: عبر قناة مشفرة معتمدة (VPN/بوابة Zero-Trust) بحساب موثق وMFA، ومن الأجهزة المعتمدة المدارة فقط.

(DAF-POL-ICT-01-30) تُراجع الصلاحيات دوريًا: مراجعة ربع سنوية للحسابات المميزة وسجلات الوصول للأنظمة الحساسة، ومراجعة نصف سنوية لكامل الصلاحيات مع مالكي الأنظمة لإسقاط ما تعفا عن الحاجة، ويُوثَّق كل مراجعة بمحضر يوقعه المراجع ومالك النظام.

8.2 التشفير

(DAF-POL-ICT-01-31) تُطبق أحكام التشفير الآتية:

النطاق	الضوابط الدنيا
التخزين (At Rest)	تشفير الأقراص الكاملة للأجهزة المحمولة والمكتبية (BitLocker/FileVault أو ما يعادلها)، وتشفير قواعد البيانات الحساسة وملفاتها، وتشفير وسائط النقل القابلة للنقل
النقل (In Transit)	بروتوكولات حديثة معتمدة (TLS 1.2 فأحدث) لجميع الخدمات، ومنع بروتوكولات الإدارة غير المشفرة (Telnet/FTP/SMBv1)
المفاتيح	إدارة مفاتيح مركزية، فصل المفاتيح عن بياناتها، تخزين آمن للمفاتيح الخاصة، وتدوير دوري، وعدم تضمين المفاتيح في أكواد البرمجيات

وتُراجع الخوارزميات والبروتوكولات دوريًا لمواءمتها مع توجيهات الجهات المختصة والممارسات الصناعية المعتمدة.

8.3 النسخ الاحتياطي والتعافي

(DAF-POL-ICT-01-32) تعتمد الجهة استراتيجية نسخ احتياطي وفق المبادئ الآتية:

95. قاعدة 3-2-1 المعدلة: ثلاث نسخ على الأقل، على وسيطين مختلفين، ونسخة واحدة على الأقل معزولة أو غير قابلة للتعديل (Immutable) ضد برمجيات الفدية، وتُفضَّل نسخة خارج الموقع أو سحابية معتمدة.
96. دورية النسخ: النسخ اليومي التزايدي والنسخة الكاملة أسبوعيًا كحد أدنى للأنظمة التشغيلية، وتُعاير الدوريات بأهمية النظام وفق حقول التخصيص.

97. أهداف RPO/RTO: تُحدد أهداف الاسترداد لكل نظام حرج (مثال استرشادي: أنظمة المستفيدين والتبرعات RPO أربع وعشرون ساعة / RTO ثماني وأربعون ساعة، والبريد والملفات RPO أربع وعشرون ساعة / RTO اثنتان وسبعون ساعة، وتُثبت القيم الفعلية في حقول التخصيص).
98. اختبار الاستعادة: تُختبر استعادة نسخة كاملة لنظام حرج كل ثلاثة أشهر على الأقل، وتُوثَّق النتائج والفجوات وخطط المعالجة.
99. سرية النسخ: تُشفَّر النسخ الاحتياطية أثناء التخزين والنقل، وتُقيَّد صلاحيات الوصول إليها، وتدخل ضمن سجل المعالجة ودورة حياة بياناتها (إتلاف آمن عند انتهاء عمرها).
100. العزل والتنظيف: تُفحص النسخ المستعادة بعد أي حادثة اختراق قبل إعادة تشغيلها (Re-imaging) لضمان خلوها من العدوى.

8.4 أمن الشبكات

(DAF-POL-ICT-01-33) تُقسم شبكة الجهة وتُحمى وفق الآتي:

101. تجزئة الشبكة (Segmentation) لعزل: شبكة الخوادم والأنظمة الحساسة، وأجهزة الموظفين، وأجهزة الزوار والضيوف (Guest WiFi) بلا وصول للأنظمة الداخلية)، وأجهزة تقنية المعلومات الإدارية.
102. جدار حماية (Firewall) بقواعد «الرفض الافتراضي» (Deny by Default) يُراجَع ربع سنويًا لإزالة القواعد الميتة.
103. حماية نقطة النهاية (EDR/Next-Gen Antivirus) على جميع الأجهزة المدارة، وتحديث قواعدها آلية.
104. حماية لاسلكية: تشفير قوي (WPA2-Enterprise/WPA3)، وكلمات مرور فصل بين الشبكات، وإخفاء/تقييد بث الشبكات الحساسة.
105. منع الاتصالات الخارجية غير الضرورية من الشبكة الداخلية (Egress filtering) لكشف البرمجيات الخبيثة.
106. عند توفر الإمكان: أنظمة كشف/منع الاختراق (IDS/IPS) وسجلات مركزية (SIEM مبسط) للأنظمة الحساسة[9].

8.5 الأجهزة الطرفية والأجهزة الشخصية (BYOD)

(DAF-POL-ICT-01-34) تُدار الأجهزة وفق الآتي:

107. الأجهزة المملوكة للجهة: تسجيل في جرد الأصول، تفعيل التشفير والحماية والتحديثات الآلية، قفل تلقائي، منع تثبيت البرامج غير المعتمدة، وبرنامج إدارة أجهزة (MDM) عند توفره.
108. الأجهزة الشخصية (BYOD): يُسمح بها بضوابط: موافقة مكتوبة على سياسة الاستخدام المقبول، عزل بيانات الجهة (حاوية عمل أو ملفات مشفرة)، عدم تخزين بيانات «سري للغاية» عليها إطلاقًا، إمكانية المسح عن بُعد لبيانات الجهة دون المساس ببيانات الفرد الشخصية، وإلزام بأنظمة تشغيل مدعومة ومحينة.
109. يحظر ربط أي جهاز شخصي غير مُقيَّد بشبكة الجهة الداخلية، ويحظر توصيل وسائط تخزين خارجية مجهولة.
110. عند فقدان جهاز أو سرقته: يُبلَّغ خلال [▸ أربع ساعات] من العلم لإيقاف الحسابات عن بُعد ومسح الجهاز وتقييم أثر الحادثة وفق المبحث 12.

8.6 أمن البريد والويب والتطبيقات

(DAF-POL-ICT-01-35) تُطبق الضوابط الآتية:

111. بريد الجهة على خدمة مؤسسية تدعم MFA، مع فلترة رسائل مزيفة، واعتماد سجلات SPF وDKIM وDMARC على نطاقات الجهة لمنع انتحال بريدها[9].
112. حظر مرفقات عالية الخطورة على الأنظمة الحساسة، وتحذير المستخدمين عند رسائل خارجية، ومحاكاة تصيد دورية (المبحث 14).
113. الموقع الإلكتروني: شهادة TLS سارية، تحديث نظام إدارته وإضافاته، نسخ احتياطي، وقياس حماية من الاختراق (WAF أو خدمة تخفيف DDoS عند الاقتضاء).
114. تُحدَّث الأنظمة والتطبيقات والمتصفحات وفق جدول معالجة الثغرات في البند 8.8، ويحظر استخدام أنظمة انتهى دعمها.

8.7 التسجيل والمراقبة والتدقيق

(DAF-POL-ICT-01-36) تُسجَّل أحداث الأمن والوصول والتغيير على الأنظمة الحساسة (سجلات دخول، عمليات تصدير، تعديلات صلاحيات، حذف) وتحفظ في وسط محمي ضد العبث مدة لا تقل عن [▸ اثني عشر شهرًا] للأنظمة الحساسة، ويُقيَّد الوصول إليها بصلاحيات مميزة، وتُراجع دوريًا (ربع سنوي) للأنظمة الحساسة للكشف عن الأنشطة الشاذة، ويُوثَّق من يراجع ومتى وما وجد.

8.8 إدارة الثغرات والتحديثات

(DAF-POL-ICT-01-37) تعتمد الجهة دورة إدارة ثغرات تشمل:

الأولوية	تعريفها الاسترشادي	مهلة المعالجة
حرجة	ثغرة قابلة للاستغلال عن بُعد بأثر عالٍ على بيانات حساسة	[▸ 72 ساعة] أو عزل فوري
عالية	استغلال محتمل بأثر كبير	[▸ 14 يومًا]
متوسطة	استغلال أصعب أو أثر محدود	[▸ 30 يومًا]
منخفضة	أثر ضئيل	[▸ 90 يومًا]

وتُفحص الأنظمة الحساسة بالأدوات المؤتمتة شهريًا على الأقل، وتُفحص الأنظمة الخارجية الظاهرة للإنترنت قبل إطلاقها ودوريًا بعده، وتُوثَّق الثغرات ومعالجتها وإغلاقها.

8.9 اختبارات الاختراق

(DAF-POL-ICT-01-38) تجري الجهة اختبار اختراق لأنظمتها ومواقعها الأساسية مرة في السنة على الأقل بواسطة جهة متخصصة مستقلة، ويشمل: الأنظمة الإلكترونية المواجهة للإنترنت، ومنصات جمع التبرعات، وسير عمليات الدفع؛ ويُعدّ تقرير مكتمل بالثغرات وخطط المعالجة ومواعيدها، ويُتابع إغلاقها بمحضر تحقق، ويُطلع المجلس على النتائج الجوهرية. وتُجرى اختبارات استهدافية بعد أي حادثة جوهرية أو قبل إطلاق نظام حرج.

8.10 الأنظمة السحابية والخدمات الرقمية الخارجية

(DAF-POL-ICT-01-39) عند التعاقد على أي خدمة سحابية أو منصة رقمية تعالج بيانات الجهة:

115. تُقيَّم الخدمة قبل التعاقد (قائمة فحص المعالج 19.6) لناحية: موقع التخزين والمعالجة، ضوابط الأمن، نموذج المسؤولية المشتركة (Shared Responsibility)، شروط الإخلاء عند الإنهاء.
116. يُبرم عقد يتضمن بنود حماية البيانات (المبحث 9.3)، ويُحدَّد فيه موقع البيانات، ويمنع النقل لجهة ثالثة دون موافقة.
117. تُفعل ضوابط التقنية المتاحة من مزود الخدمة: MFA إجباري، تشفير، سجلات، نسخ احتياطي، وتقييد الوصول الإداري.
118. الخدمات المجانية الاستهلاكية العامة لا تُستخدم لتخزين أي بيانات تصنيفها «سري» فأعلى.
119. عند الإنهاء: استرداد كامل للبيانات، شهادة إتلاف من المزود، وإغلاق الحسابات.

8.11 أمن منصات جمع التبرعات والخدمات المالية

120. تُستخدم منصات جمع التبرعات المرخصة نظامًا فقط (DAF-FIN-02)، وتُقيَّد صلاحيات الإدارة عليها وتفعَّل فيها MFA وتسجيل العمليات.
121. أسرار التكامل مع بوابات الدفع (مفاتيح API) تُخزن في وسط آمن، وتُقيَّد، وتُدوَّر دوريًا، ولا تُدرج في رسائل أو مستندات.
122. تُراجع عمليات السداد والاسترداد والتسويات شهريًا ضد سجلات الجهة المالية.

المبحث 9: المشاركة الخارجية والمعالجون والمقاولون

9.1 مبدأ المشاركة المشروعة

(DAF-POL-ICT-01-40) لا تُفصح الجهة عن بيانات شخصية لأي طرف خارجي إلا إذا تحقق واحد من الآتي: (1) موافقة صاحب البيانات على الإفصاح؛ (2) وجود التزام نظامي يوجب الإفصاح؛ (3) إبرام اتفاقية تتضمن مصلحة مشروعة موثقة تقضي بالإفصاح وبأقل بيانات[1]. ويحظر الإفصاح في الحالات المنعية نظامًا (منها الإفصاح عن بيانات حساسة بقصد الإضرار، أو الإفصاح التجاري غير المشروع)، ويُوثَّق كل إفصاح في قائمة المشاركات (19.4) ويُقيَّد المتلقي باستخدام البيانات للغرض المتفق عليه وحده.

9.2 اختيار المعالج وإشراف الجهة عليه

(DAF-POL-ICT-01-41) وفقًا لنظام حماية البيانات الشخصية، تلتزم الجهة في تعاملها مع معالجيها بالضوابط الآتية[1]

123. اختيار أمين: لا يُعهد بالمعالجة إلا لمن يقدم كفايات وضمانات فنية وتنظيمية تثبت قدرته على حماية البيانات، ويُجرى فحص مسبق (قائمة 19.6) قبل التعاقد وتجديده.
124. عقد مكتوب: لا يبدأ أي معالجة باسم الجهة دون اتفاقية مكتوبة تتضمن البنود النظامية الدنيا.
125. الإشراف: تراقب الجهة امتثال المعالج (تقارير، اجتماعات دورية، حق التدقيق)، وتتحقق من تنفيذ التعليمات، ويعالج المخالف فورًا بإنذار وتصحيح أو إيقاف وإنهاء عند الجسامة.
126. تعديل التعليمات: لا يجوز للمعالج أن يتجاوز تعليمات الجهة الموثقة؛ فأي معالجة خارجها تُعد مخالفة تستوجب الإجراءات النظامية والتعاقدية.

9.3 بنود ملحق معالجة البيانات (الحد الأدنى)

(DAF-POL-ICT-01-42) يتضمن عقد المعالجة (أو ملحقه) الحد الأدنى الآتي:

127. طبيعة المعالجة وفئات البيانات وفئات أصحابها وفترتها (وصف الأنشطة المطلوبة).
128. أغراض المعالجة المحددة والتزام المعالج بعدم تجاوزها وعدم معالجتها لمصلحته الخاصة.
129. التزامات السرية لأفراد المعالج المكلفين بالمعالجة.
130. تدابير الأمن الفني والتنظيمي الواجبة (مرجعيتها: هذه الوثيقة والضوابط المعتمدة).
131. تقييد المعالج من الباطن: عدم التعاقد مع أي معالج من الباطن دون موافقة خطية مسبقة من الجهة، وتدفق الالتزامات عليه، وإبقاء المسؤولية الكاملة على المعالج الأصلي.
132. حق الجهة في: طلب المعلومات، والتدقيق (بنفسها أو بمقيّم مستقل)، ومراجعة تقارير الأمن والحوادث.
133. دورة الحادث: إبلاغ الجهة بالحادث دون تأخير مفرط، والتعاون الكامل في إدارة الحادث والإخطارات النظامية.
134. حقوق صاحب البيانات: تعاون المعالج مع الجهة في الاستجابة لطلبات الأفراد.
135. ما بعد انتهاء الخدمة: إعادة البيانات بصيغة قابلة للاستخدام و/أو إتلافها وفق توجيه الجهة، وشهادة إتلاف، مع عدم الإبقاء على نسخ إلا نظامًا.
136. مساءلة المعالج والتعويض عن الإخلال بالبنود.
137. عدم النقل خارج المملكة إلا وفق لائحة النقل وبموافقة خطية مسبقة من الجهة (المبحث 10).

9.4 المعالجون من الباطن

(DAF-POL-ICT-01-43) يعتمد المسؤول التنفيذي — برأي مسؤول حماية البيانات — قائمة معالجين من الباطن مسموح بهم لكل معالج رئيسي، ولا يُقبل أي تغيير أو إضافة دون موافقة مسبقة موثقة، ويُقيَّد كل معالج من الباطن بالبنود ذاتها المفروضة على المعالج الرئيسي، ويُطلب من المعالج الرئيسي قائمة محينة كل ستة أشهر.

9.5 الإفصاح للجهات النظامية والأمنية

(DAF-POL-ICT-01-44) عند ورود طلب إفصاح من جهة نظامية أو أمنية:

138. يُتحقق من سند الطلب ونطاقه ومحدداته كتابةً، ويُحال إلى المسؤول التنفيذي أو من يفوضه.
139. يقتصر الإفصاح على الحد الذي يلزم نظامًا، ويُسجَّل في قائمة المشاركات مع الجهة والغرض والتاريخ والفئات المفصح عنها.
140. يُفصح لصاحب البيانات عن الإفصاح النظامي متى لم يكن الإفصاح عن ذلك ممنوعًا نظامًا.
141. يتقيد الموظف بأحكام السرية النظامية، ويحظر الاتصال الجزئي أو التمهيدي خارج القنوات الرسمية المعتمدة.
142. الطلبات الواردة من خارج المملكة تُراجع من منظور لائحة النقل قبل الاستجابة (المبحث 10).

المبحث 10: نقل البيانات الشخصية خارج المملكة

10.1 المبدأ العام

(DAF-POL-ICT-01-45) يجوز نقل البيانات الشخصية خارج المملكة أو الإفصاح عنها لطرف خارجها في الحدود التي يجيزها النظام ولائحة النقل، وبعد استيفاء الضوابط التالية مجتمعة[1][3]

143. ألا يخل النقل بأمن المملكة ومصالحها أو بحقوق وحريات الأفراد.
144. ألا يكون النقل مؤثرًا على مستوى حماية البيانات الشخصية في المملكة سلبًا.
145. ألا يتجاوز النقل الحد الأدنى الضروري من البيانات المرتبط بالغرض.
146. وجود ضمانات كافية تكفل حماية البيانات ومستوى لا يقل عن مستوى الحماية في المملكة (عقد ببنود نظامية صريحة، أو التزام نظامي معادل).

10.2 حالات النقل المشروعة

حالة النقل	شرطها الجوهري	توثيقه في الجهة
تقييم الجهة المختصة لملاءمة مستوى الحماية في وجهة النقل	النقل لجهة خاضعة لتقييم ملاءمة معتمد من الجهة المختصة بما فيه تحديد القطاعات أو البنى التحتية[3]	نسخة من التقييم ومرجعه في قائمة المشاركة
الضمانات المناسبة: بنود تعاقدية نموذجية (SCCs) معتمدة أو قواعد ربط ملزمة (BCRs)	إبرام العقد بالنموذج المعتمد دون تعديل جوهري	نسخة العقد وساريته
حالات الضرورة والاستثناءات النظامية	مصلحة حيوية، التزام اتفاقية دولية، أغراض أمنية أو عدلية، أو ما تقره اللائحة	مذكرة مسببة بقرار المسؤول التنفيذي ومسؤول الحماية
موافقة صاحب البيانات بعد إفصاحه بوجهة النقل	موافقة صريحة مستقلة بعد إبلاغه بالوجهة والضمانات	نسخة الموافقة وسجلها

10.3 تقييم المخاطر قبل النقل

147. يُجرى تقييم مخاطر مكتوب لكل نقل يتضمن بيانات حساسة أو يتم على نطاق واسع، ويشمل: أحكام النظام في وجهة النقل، السياسات والضوابط الفعلية لدى المتلقي، التزامات المتلقي بأحكام العقد والتحكيم والتعويض، وطلبات السلطات الأجنبية المحتملة[3].
148. يُرفق التقييم بقائمة المشاركة، ويُراجع عند تغيّر وجهة النقل أو طبيعته.

10.4 ضوابط ما بعد النقل

149. إخطار صاحب البيانات بوجهة النقل وأساسه وضماناته عند اللزوم، وإبلاغه بأن وجهة النقل قد تختلف أحكام نظامها عن نظام المملكة[1].
150. تدوير المعالجات الخارجية ومراجعتها ضمن قائمة المشاركات.
151. عند انتهاء العلاقة: استرداد أو إتلاف البيانات بشهادة من المتلقي.
152. يستمر واجب الجهة في حماية البيانات المنقولة؛ فالنقل لا ينقل معه المسؤولية.

10.5 متابعة التعديلات المقترحة

تلتزم الجهة بمتابعة مقترحات المسودة الجاري استطلاعها، وفي مقدمتها اشتراط تخزين البيانات الشخصية داخل المملكة، وإخضاع النقل خارج المملكة لقيود أشد مع توسيع فئات الملزمين بالتسجيل[8]؛ فإذا اعتُمدت التعديلات حدَّثت الإجراءات خلال ستين يومًا من النفاذ ونقلت الأنظمة السحابية ذات التخزين الخارجي إلى بدائل متوافقة أو معتمدة، وأوقفت أي نقل لم يعد مشروعًا.

المبحث 11: الإعلان والتسويق المباشر

تلتزم الجهة في معالجاتها للإعلان والتسويق المباشر بضوابط النظام ولائحته[1][2] (DAF-POL-ICT-01-46)

153. لا تُرسل مواد إعلانية أو تسويقية إلا بموافقة مستوفية، أو — في حالات التواصل غير المباشر — لمن له تعامل سابق مع الجهة وفق ما تقره اللائحة، ومع توفر وسيلة إيقاف سهلة مجانية.
154. يُعرَّف المرسل صراحة دون تمويه في كل رسالة، وتُحفظ أدلة الموافقة وأوقات السحب.
155. لا يعالج البيانات لأغراض التسويق المباشر إلا بموافقة، وعند سحبها تتوقف الجهة فورًا عن إرسال المواد وعن المعالجة المبنية عليها.

156. عند سحب الموافقة لا يكتفي بإيقاف الإرسال، بل تُتلف — بلا إبطاء — البيانات المولدة من معالجة التسويق لذلك الشخص ما لم يوجد أساس نظامي مستقل، ويتعزز هذا الوجوب في الصيغة المقترحة بالمسودة[8].

157. تُراعى قواعد المركز الوطني لتنمية القطاع غير الربحي وأنظمة الاتصالات في الرسائل الجماعية (DAF-COM-01 وDAF-FIN-02)، وتُوثق كل حملة برقم مرجعي وقائمة استهداف.

المبحث 12: حوادث البيانات والاستجابة للحوادث السيبرانية

12.1 التعريف والتصنيف

تُعدّ «حادثة» كل حدث يؤدي إلى وصول غير مشروع إلى البيانات الشخصية أو إتلافها أو فقدانها أو تعديلها أو إفصاحها أو حدوث خرق لأمنها. وتصنف الجهة الحادثة عند العلم بها وفق الآتي:

الدرجة	الوصف	أمثلة	مستوى التصعيد
منخفضة	أثر محدود محلي قابل للاحتواء السريع	جهاز واحد مصاب دون بيانات حساسة	منسق الأمن
متوسطة	وصول غير مصرح به لبيانات داخلية أو تعطل نظام	حساب مخترق، بريد تصيد ناجح	المسؤول التنفيذي
عالية/حرجة	بيانات حساسة متأثرة، أو تعطل منصة تبرعات، أو برمجية فدية	تسرب قاعدة بيانات مستفيدين	المجلس + الإشعارات النظامية

12.2 فريق الاستجابة والأدوار

158. القائد: المسؤول التنفيذي (أو نائبه المفوض) — يقرر التصعيد والإخطارات الخارجية.

159. الإدارة التنظيمية والإخطارية: مسؤول حماية البيانات — تقييم الأثر على البيانات الشخصية، وإعداد إشعارات سدايا والأفراد، والتواصل مع الجهة المختصة.

160. الاستجابة التقنية: منسق الأمن/تقنية المعلومات — احتواء تقني، تحليل جنائي رقمي أولي، تعافٍ، حفظ أدلة.

161. الدعم: مالك النظام المعني، الشؤون القانونية/المراجعة القانونية، الاتصال والإعلام (لأي إفصاح خارجي معتمد)، الموارد البشرية عندما يكون الفاعل داخليًا.

12.3 خطة الاستجابة والاحتواء

تعتمد الجهة خطة استجابة بمراحل، وتختبرها بمحاكاة سنوية على الأقل (DAF-POL-ICT-01-47):

162. التحضير: فريق معلن، جهات اتصال محينة، أدوات عزل ومسح، قوالب إشعار جاهزة (12.5)، صلاحيات مسبقة للإجراءات الطارئة.

163. الرصد والتحليل: تأكيد الحادث وفصله عن الضجيج، وتقييم أولي سريع للنطاق (الأنظمة، البيانات، الأشخاص).

164. الاحتواء: عزل الأجهزة المصابة، إيقاف الحسابات المخترقة، حظر مؤشرات الهجوم، حماية النسخ الاحتياطية، منع الانتشار؛ ويكون الاحتواء سريعًا وموثقًا مع حفظ الأدلة قبل التغييرات الجذرية متى أمكن.

165. الاستئصال: إزالة العدوى والأسباب الجذرية (إعادة بناء الأنظمة المصابة من مصادر موثوقة، تدوير الأسرار المكشوفة، تصحيح الثغرة المستغلة).

166. التعافي: استعادة من نسخ نظيفة، مراقبة معززة بعد العودة، واستئناف تدريجي للخدمات.

167. الدروس المستفادة: تقرير ما بعد الحادث خلال [▸ عشرة أيام عمل] يتضمن الجدول الزمني والأسباب الجذرية والأثر وتقييم الإجراءات وخطة تحسين، ويُعرض على المجلس في حوادث الدرجتين المتوسطة فأعلى.

12.4 تقييم الضرر ودرجة الخطورة

عند تقييم ما إذا كانت الحادثة متوقعًا أن تلحق ضررًا بأصحاب البيانات أو تعارض حقوقهم ومصالحهم، تراعي الجهة: فئة البيانات المتأثرة (عادية/حساسة)، عدد الأشخاص، طبيعة الوصول (قراءة/نسخ/تعديل/نشر)، قابلية الاستغلال، وجود ضوابط وقائية (تشفير يحول دون القراءة)، وحدة الإجراءات التصحيحية. ويُوثَّق التقييم بقرار مكتوب من مسؤول حماية البيانات يحدد: وجوب إشعار الجهة المختصة، ووجوب إخطار الأفراد، ونطاق كلٍّ منهما[4].

12.5 إشعار الجهة المختصة (سدايا) خلال 72 ساعة

(DAF-POL-ICT-01-48) كل حادثة يتوقع أن تلحق ضررًا بالبيانات الشخصية أو أصحابها أو تتعارض مع حقوقهم ومصالحهم تُبلَّغ الجهة المختصة خلال (72) ساعة من علم الجهة بها، عبر خدمة إشعار حوادث البيانات في منصة الحوكمة الوطنية للبيانات، وتتضمن البيانات — وفق دليل سدايا — ما يلي[4]

168. وصف الحادثة وطبيعتها ووقت وقوعها وكيفية علم الجهة بها وتاريخ العلم.
169. فئات أصحاب البيانات المتأثرين وعددهم التقريبي.
170. فئة البيانات وطبيعتها وحساسيتها.
171. التدابير التي اتخذتها الجهة أو تعتزم اتخاذها لمعالجة الحادثة وآثارها.
172. إن كانت الجهة قد أخطرت أصحاب البيانات وأسباب ذلك إن لم تُبلغهم.
173. بيانات التواصل للجهة ومسؤول حماية بياناتها.

ويجوز تقديم إشعارًا أوليًا داخل المهلة ثم استكمالًا لاحقًا إذا تعذر استيفاء كل العناصر أولًا؛ وإذا لم يتضح أثر الحادثة خلال المهلة يُقدَّم إشعار تحفظي ثم يُستكمل. وعلى المعالج أن يبلغ الجهة بالحادث دون تأخير مفرط لتتمكن الجهة من وفاء التزامها، ويحظر التعاقد على نقل هذا الالتزام أو اشتراط موافقة المعالج على الإشعار[4].

12.6 إخطار أصحاب البيانات

(DAF-POL-ICT-01-49) إذا قيّمت الجهة أن الحادثة قد تلحق ضررًا يمس صاحب البيانات أو يتعارض مع حقوقه ومصالحه، أخطرته دون تأخير مفرط، وفي أقرب وقت عملي، وبأسلوب واضح مبسط يناسب طبيعة الجمهور (ويشمل ذوي الإعاقة وكبار السن عند الاقتضاء)، ويشتمل على: وصف الحادثة بلغة غير تقنية، وبيانات التواصل، والعواقب المرجحة، والتدابير المتخذة والمقترحة لحمايته، وما يمكنه فعله لحماية نفسه[4]. وتنسق الجهة إخطارها مع الجهة المختصة متى طلبت ذلك.

12.7 إبلاغ الجهات الأخرى ذات الصلة

174. إذا كانت الجهة مصنفة نظامًا ضمن المنشآت الحيوية أو الجهات الحكومية، تلتزم بالإبلاغ عن الحوادث السيبرانية الجوهرية للهيئة الوطنية للأمن السيبراني وفق قنواتها ومواعيدها[9].
175. البلاغات الجنائية للجهات المختصة عند توافر مؤشرات جريمة معلوماتية وفق نظام مكافحة الجرائم المعلوماتية[12].
176. الجهات المالية والتأمينية وفق العقود (DAF-FIN-01) عند تأثر المعاملات المالية.

12.8 التوثيق

يُنشأ ملف لكل حادثة (بطاقة الحادث 19.3) يوثق: الجدول الزمني والأدلة والقرارات والإشعارات المرسلة والنماذج المستخدمة والنتائج، ويحفظ مدة لا تقل عن خمس سنوات، ويُقيَّد الوصول إليه بمن شارك في الاستجابة.

المبحث 13: استمرارية الأعمال والتعافي من الكوارث

(DAF-POL-ICT-01-50) تعتمد الجهة خطة استمرارية مبسطة تتناسب مع حجمها لضمان استمرار الخدمات الجوهرية (استقبال التبرعات، إدارة المستفيدين، الرواتب) عند الكوارث، تتضمن: تحليل الأثر على الأعمال (BIA) يحدد الأولويات وأهداف RTO/RPO المعتمدة في البند 8.3، وبدائل التشغيل (العمل اليدوي المؤقت، الأنظمة البديلة، مزودو خدمات بدلاء)، وقائمة تواصل طارئة، واختبارًا سنويًا (تمرين مكتبي أو فني) موثقًا بنتائجه ومعالجاته. وتُحدَّث الخطة عند تغيّر الأنظمة أو الفريق.

المبحث 14: التوعية والتدريب السيبراني

(DAF-POL-ICT-01-51) تعتمد الجهة برنامجًا للتوعية والتدريب يشمل:

177. عند الالتحاق (وجوبًا): تعريف إلزامي بأمن المعلومات وحماية البيانات وسرية البيانات وإقرار الاستخدام المقبول قبل منح أي صلاحية.
178. دوري (سنويًا على الأقل): تدريب إلزامي لجميع المستخدمين في أمن المعلومات وحماية البيانات، محتواه مصمم على وقائع الجهات غير الربحية (تصيد يستهدف التبرعات، انتحال جهات مانحة).
179. محاكاة التصيد: رسائل اختبار دورية (ربع سنوية استرشاديًا) مع تدريب فوري لمن يتفاعل.
180. متخصص: تدريب معمق لمالكي الأنظمة والمسؤولين المميزين ومسؤول حماية البيانات وفريق الاستجابة، واجتياز دورات معتمدة في الأمن السيبراني لمنسق الأمن.
181. السجل: تُوثق الخطط والحضور والنتائج، ويُقاس إتمام التدريب كمؤشر أداء (المبحث 15.3)، ويُعالج من يتخلف عن التدريب الإلزامي وفق DAF-HR-04.

المبحث 15: الامتثال والمراجعة والتحسين

15.1 المراجعة والتدقيق

(DAF-POL-ICT-01-52) تخضع منظومة حماية البيانات والأمن للمراجعة الآتية:

182. مراجعة داخلية سنويًا على الأقل تغطي: سجل المعالجة والتسجيلات النظامية، وضوابط الوصول ومراجعاتها، والنسخ الاحتياطي واختباراته، وإدارة الحوادث، وعقود المعالجين.
183. مراجعة إدارة عليا برئاسة المسؤول التنفيذي نصف سنوية لمتابعة المخاطر والملاحظات وخطط المعالجة.
184. مراجعة خارجية (تدقيق أمني أو اختبار اختراق) عند الاقتضاء أو بطلب الجهات المانحة.
185. تُغلق الملاحظات بخطط معالجة بمواعيد ومالكين، وتُتابع حتى الإغلاق، وتُرفع النتائج إلى المجلس.

15.2 التعامل مع الجهة المختصة

تلتزم الجهة بـ: التسجيل والتحديث في منصة الحوكمة الوطنية، والرد على طلبات الجهة المختصة في المهل النظامية (وتُعد الإجراءات بمهلة عشرين يوم عمل فور اعتماد المسودة)[8]، وتمكين الجهة المختصة من الاطلاع على سجلات المعالجة، والتعاون في التحقيقات، وتنفيذ قراراتها بعد تمكين الجهة من إبداء الرأي حيث يتيح النظام ذلك. وتتلقى شكاوى أصحاب البيانات عبر قناة معلنة وتعالجها بجدية وحياد.

15.3 مؤشرات الأداء الرئيسية (KPIs)

المؤشر	الهدف	الدورية
نسبة إتمام التدريب الإلزامي	[► 100%]	ربع سنوي
نسبة إغلاق ملاحظات المراجعة في موعدها	[► ≥ 90%]	نصف سنوي
زمن إيقاف حسابات المنتهية	[► ≤ 24 ساعة]	ربع سنوي
نسبة الأجهزة المدارة المطابقة (تشفير، حماية، تحديث)	[► ≥ 95%]	شهري
نجاح اختبارات استعادة النسخ	[► 100%]	ربع سنوي
زمن اكتشاف الحوادث وإشعارها	ضمن المهل (72 ساعة لسدايا)	لكل حادثة
نسبة طلبات الأفراد المنجزة في المهلة	[► 100%]	شهري
نسبة المعالجين الخاضعين لعقود مكتملة البنود	[► 100%]	نصف سنوي

المبحث 16: المخالفات والجزاءات

186. التأديب الداخلي: كل مخالفة لهذه الوثيقة تُعامل وفق وثيقة المخالفات والجزاءات DAF-HR-04، وتشمل المخالفات الجسيمة: إفشاء البيانات، مشاركة بيانات الدخول، تعطيل الضوابط، إخفاء حادثة، إساءة استخدام البيانات لغرض شخصي. ويجوز الوقوف عن العمل احترازيًا عند الحاجة لحماية الأدلة أو البيانات.

187. الجزاءات النظامية: مخالفة أحكام النظام قد تستوجب — بحسب طبيعتها — تحذيرًا أو غرامة لا تتجاوز خمسة ملايين ريال تُضاعَف عند التكرار، وتُراعى أسباب التخفيف النظامية المقرة بالتعديل (كالعذر المقبول والإبلاغ الذاتي والتعاون)[17]؛ والإفصاح عن بيانات حساسة بقصد الإضرار بصاحبها أو تحقيق مصلحة خاصة جريمة تعاقب بالسجن حتى سنتين و/أو غرامة حتى ثلاثة ملايين ريال؛ ويحق لصاحب الضرر التعويض وفق النظام[17].

188. الإبلاغ عن المخالفات: يحمي الإجراء الداخلي من يبلغ بحسن نية عن مخالفة أو ثغرة من أي عقوبة، وتُعالج البلاغات بسرية وفق قنوات الإبلاغ في DAF-ETH-01 وDAF-HR-04.

(DAF-POL-ICT-01-53) يُقصد بالجزاء هنا ما يُقرره النظام أو لائحته أو قرار الجهة المختصة، وتُوثَّق كل مخالفة داخلية ذات بعد نظامي وتُعرض على المراجعة القانونية لتقدير وجوب الإبلاغ النظامي، ويُمنع أي تدبير داخلي من أن يكون بديلًا عن إبلاغ نظامي واجب.

المبحث 17: أحكام عامة

189. هذه الوثيقة وثيقة داخلية ملزمة لمن يشملهم نطاقها، ولا تُعد إخلالًا بأي التزام نظامي أشد، ولا منحًا لأي حق نظامي لأي طرف.

190. تُفسَّر أحكامها بما يوافق النظام ولائحته؛ وعند الشك تُحال المسألة إلى المراجعة القانونية ومسؤول حماية البيانات.

191. لا يجوز الاتفاق على مخالفة أحكامها، وأي اتفاق أو تفويض يخالفها يُعد كأن لم يكن في حدود المخالفة.

192. الحقول المعقوفة بعلامة [▸] حقول تخصيص تستكمل وفق المبحث 18، ولا يكتمل الامتثال قبل استكمالها واعتمادها.

193. تُنشر الوثيقة عبر قنوات الجهة الداخلية المعتمدة، ويُثبت العلم والاطلاع عليها لكل مستخدم.

المبحث 18: حقول التخصيص

تُستكمل الحقول الآتية قبل الاعتماد، ويُعد عدم استكمالها موجبًا لتعليق الاعتماد:

#	الحقل	بيان التخصيص
1	اسم الجهة وشكلها النظامي (جمعية أهلية/مؤسسة أهلية/تعاونية/غيرها) ورقم الترخيص	▸ .....
2	جهة الإشراف النظامي على الجهة (الوزارة/المركز الوطني لتنمية القطاع غير الربحي/غيرها)	▸ .....
3	حالة التسجيل في السجل الوطني للمسؤولين: مسجلة/ملزمة ولم تسجل/غير ملزمة، ورقم الشهادة وتاريخها	▸ .....
4	حالة تعيين مسؤول حماية البيانات: معين (الاسم والبيانات)/ملزم ولم يُعين/غير ملزم، وسجل بياناته على المنصة	▸ .....
5	الأنظمة المعلوماتية المعتمدة لدى الجهة ومالكو كل منها	▸ .....

#	الحقل	بيان التخصيص
6	فئات البيانات الحساسة المعالجة فعلًا ومبرراتها وأسسها النظامية	▸ .....
7	المعالجون المعتمدون (أنظمة، منصات تبرع، اتصالات، تسويق، سحابة) وحالة عقودهم	▸ .....
8	وجود نقل للبيانات خارج المملكة: لا يوجد/يوجد (الحالات والضمانات والعقود)	▸ .....
9	منصات جمع التبرعات المرخصة المتعاقد معها	▸ .....
10	مزودو البريد والخدمات السحابية ومواقع تخزين البيانات (داخل/خارج المملكة)	▸ .....
11	مدة الاحتفاظ المعتمدة لكل فئة بيانات مقارنةً بجدول المبحث 5.8	▸ .....
12	سياسة كلمات المرور المعتمدة (الأطوال والتعقيد)	▸ .....
13	أهداف RPO/RTO المعتمدة لكل نظام حرج	▸ .....
14	دورية النسخ الاحتياطي المعتمدة وطريقة العزل وأماكن النسخ	▸ .....
15	مهل معالجة الثغرات المعتمدة (عند المخالفة للجدول 8.8)	▸ .....
16	ساعة إيقاف الحسابات المنتهية ومهل التعديل عند التحول الوظيفي	▸ .....
17	المهلة المحددة لإتلاف البيانات بعد انتهاء الاحتفاظ	▸ .....
18	قنوات استقبال طلبات الأفراد والشكاوى (البريد/النموذج/الهاتف) وقائمة الرد	▸ .....
19	نطاق اختبار الاختراق السنوي والجهة المنفذة وموازنته	▸ .....
20	خطة التدريب السنوية ومسؤولها وميزانيتها وبرنامج المحاكاة	▸ .....
21	ميزانية الأمن السيبراني وخطة الأمن السنوية	▸ .....
22	الجهة المنفذة للمراجعة الداخلية (داخلي/خارجي) وجدولها	▸ .....
23	شروط مانحين أو شركاء تفرض ضوابط	▸ .....

#	الحقل	بيان التخصيص
	أشد على البيانات (تُلحق وتلزم)	
24	شروط استخدام الأجهزة الشخصية المقبولة لدى الجهة (MDM، الفئات المسموح لها)	▸ .....
25	قناة الإبلاغ الداخلي عن المخالفات والحوادث ومسؤولها	▸ .....
26	مدة حفظ سجلات التدقيق المعتمدة وسجلات طلبات الأفراد	▸ .....
27	مصفوفة تصنيف البيانات المعتمدة محليًا (عند الاختلاف عن المبحث 4)	▸ .....
28	أي استثناء معتمد من هذه الوثيقة بقرار مكتوب مسبب من المجلس	▸ .....

المبحث 19: قوائم الفحص والنماذج

19.1 قائمة فحص الجاهزية لأمن المعلومات وحماية البيانات (تُنجز سنويًا)

#	بند الفحص	المرجع	نعم/لا/غير منطبق	ملاحظات
1	اعتماد الوثيقة وتحديثها ونشرها وإثبات الاطلاع	هذه الوثيقة		
2	استكمال حقول التخصيص واعتمادها	المبحث 18		
3	التسجيل/التحديث في السجل الوطني للمسؤولين وسريان الشهادة	قواعد السجل الوطني		
4	تعيين مسؤول حماية البيانات وتسجيل بياناته (متى لزم)	قواعد التعيين		
5	سجل المعالجة محين ويغطي جميع الأنظمة والقنوات	المبحث 6		
6	سياسة الخصوصية والإشعارات منشورة ومحدثة وسهلة	المبحث 5.4		
7	تقييمات الأثر للمعالجات الواردة في المبحث 7.1	المبحث 7		
8	جرد الأصول محين (آخر مراجعة خلال 6 أشهر)	المبحث 4.3		

#	بند الفحص	المرجع	نعم/لا/غير منطبق	ملاحظات
9	مراجعات الصلاحيات منجزة وموثقة (ربع سنوية للمميزة)	البند 8.1		
10	MFA مفعَّل على النطاقات الإلزامية وبنسبة التعميم المعتمدة	البند 8.1		
11	التشفير مطبق على الأجهزة والبيانات الحساسة والنقل	البند 8.2		
12	النسخ الاحتياطي: 3-2-1، نسخة معزولة، واختبار استعادة ناجح	البند 8.3		
13	تجزئة الشبكة وجدار الحماية وشبكة الضيوف	البند 8.4		
14	حماية النهايات (EDR/AV) على الأجهزة المدارة بنسبة ≥ 95%	البند 8.4		
15	ضوابط BYOD: عزل بيانات الجهة ومنع «سري للغاية»	البند 8.5		
16	SPF/DKIM/DMARC معتمدة على نطاقات البريد	البند 8.6		
17	سجلات تدقيق محفوظة ومراجعة ربع سنوية للحساسة	البند 8.7		
18	فحوص الثغرات شهرية ومعالجة ضمن المهل	البند 8.8		
19	اختبار اختراق سنوي ومعالجة نتائجه	البند 8.9		
20	عقود المعالجين مكتملة البنود وموافقات المعالجين من الباطن	المبحث 9		
21	حالات النقل خارج المملكة موثقة بضماناتها وتقييماتها	المبحث 10		
22	خطة الاستجابة للحوادث وقوالب الإشعار ومحاكاة سنوية	المبحث 12		
23	التدريب الإلزامي مكتمل ومحاكاة التصيد منفذة	المبحث 14		

#	بند الفحص	المرجع	نعم/لا/غير منطبق	ملاحظات
24	المراجعة الداخلية منجزة وملاحظاتها مغلقة أو لها خطط	المبحث 15		
25	مؤشرات الأداء مقيسة ومفصولة للمجلس	المبحث 15.3		
26	خطة استمرارية الأعمال مختبرة	المبحث 13		
27	إجراءات حقوق الأفراد (قناة وسجل ومهل) عاملة	المبحث 5.7		
28	متابعة مسودة تعديلات اللائحة والتزام الجهة بالاستطلاع	المبحث 10.5		

19.2 نموذج سجل معالجة البيانات (ROPA)

الحقل	البيان
رقم النشاط في السجل	
اسم النشاط/النظام ومالكه	
وصف المعالجة وسير البيانات (من أين إلى أين)	
الأغراض (محددة)	
فئات أصحاب البيانات	
فئات البيانات (مع تمييز الحساسة)	
الأساس النظامي لكل غرض (ومرفق الموافقة/التقييم)	
فئات المتلقين (داخلي/خارجي)	
نقل خارج المملكة؟ (نعم/لا) — الوجهة والضمانة والعقد	
فترة الاحتفاظ ومبررها وآلية الإتلاف	
التدابير التنظيمية والفنية للحماية	
تقييم أثر (DPIA) مرجعه ونتيجته (متى لزم)	
رابط إشعار الخصوصية الخاص بالنشاط	
المعالجون المشاركون والعقود المرجعية	
تاريخ آخر تحديث ومن حدَّثه	

19.3 نموذج بطاقة حادث بيانات (سرّي — يقفل بعد كل حادثة)

الحقل	البيان
رقم الحادثة وتاريخ فتحها ومصدر الرصد	
وصف الحادثة والأنظمة والبيانات المتأثرة	
الجدول الزمني: وقوع، علم، احتواء، إشعار	
فئات البيانات (عادية/حساسة) وعدد الأشخاص المتأثرين التقريبي	
تقييم الأثر: الضرر المحتمل، الضوابط الوقائية الفاعلة	
قرار الإشعار: سدايا (نعم/لا) ومبرر القرار، الأفراد (نعم/لا) ومبرره	
تاريخ ووقت إشعار سدايا (خلال 72 ساعة؟) ومرجع الإشعار	
تاريخ إخطار الأفراد وقناته ونصه المختصر	
الإجراءات: احتواء، استئصال، تعافٍ، أدلة محفوظة	
الإبلاغات الأخرى (NCA، جنائي، مالي) ومرجعها	
الجهات المشتركة في الاستجابة	
تقرير ما بعد الحادث: الأسباب الجذرية وخطة التحسين ومالكها	
تاريخ الإغلاق واعتماد الإغلاق (المسؤول التنفيذي/مسؤول الحماية)	

19.4 قائمة مشاركة/إفصاح البيانات لطرف خارجي

الحقل	البيان
رقم المشاركة وتاريخها والمسؤول الداخلي عنها	
الطرف المتلقي (اسم وجهة وجهة اتصال ودولة الإقامة)	
فئات البيانات المشتركة وحساسيتها وعدد الأشخاص تقريبًا	
الغرض من المشاركة وأساسها النظامي	
هل المتلقي معالج أم طرف ثالث؟ والعقد المرجعي	
الضمانات (SCCs/تقييم ملاءمة/التزام نظامي) ومرفقاتها	
هل نقل خارج المملكة؟ (الوجهة والمادة النظامية)	
مدة المشاركة وآلية الإنهاء والإتلاف	
موافقة صاحب البيانات إن كانت أساسًا (مرفقة)	
قرار الاعتماد (الاسم/التاريخ/التوصية)	
تاريخ المراجعة الدورية القادمة	

19.5 نموذج طلب صاحب بيانات (DSR)

الحقل	البيان
رقم الطلب وتاريخ الاستلام والقناة	
اسم صاحب البيانات وبيانات التواصل	
الحق المطلوب ممارسته (وصول/نسخة/تصحيح/إتلاف/سحب موافقة/اعتراض)	
نتيجة التحقق من الهوية (الوسيلة والتاريخ)	
الأنظمة والبيانات التي شملها البحث	
النتيجة والرد المختصر وأساس أي رفض جزئي/كلي	
تاريخ إرسال الرد والمهلة المستغرقة (30+30 يومًا)	
الإجراءات التنفيذية (تصحيح فعلي/إتلاف/إخطار متلقين)	
ملاحظات (شكوى لدى الجهة المختصة؟)	

19.6 قائمة فحص المعالج/المقاول الخارجي (قبل التعاقد وعند التجديد)

#	بند الفحص	نعم/لا/غير منطبق	ملاحظات
1	الهوية النظامية والترخيص للنشاط موثقان		
2	موقع التخزين والمعالجة معلنان (داخل/خارج المملكة)		
3	سياسات أمن معلنة أو شهادات سارية (ISO SOC2/27001 أو ما يعادلها)		
4	ضوابط الوصول والتشفير والنسخ الاحتياطي لديه موثقة		
5	إجراءات إدارة الحوادث وإبلاغ الجهة «دون تأخير مفرط»		
6	البنود التعاقدية الدنيا (المبحث 9.3) مدرجة كاملة		
7	المعالجون من الباطن معلنون وموافق عليهم		
8	آلية الاسترداد والإتلاف عند الإنهاء وشهادته		
9	حق التدقيق والتفتيش معلن		

#	بند الفحص	نعم/لا/غير منطبق	ملاحظات
10	التزام بعدم النقل خارج المملكة إلا بموافقة خطية		
11	نموذج المسؤولية المشتركة للخدمات السحابية مفهوم		
12	نتيجة التقييم: مقبول/مقبول بشروط/مرفوض، واعتماد المسؤول التنفيذي		

المبحث 20: قائمة مراجعة الجودة (تُنجز قبل الاعتماد والنشر)

#	معيار الجودة	متحقق	ملاحظات
1	اكتمال البنية: صفحة تحكم، مقدمة، أهداف، نطاق، تعريفات، أدوار، سياسات مرقمة، إجراءات، حقول تخصيص، قوائم فحص ونماذج، مراجعة جودة، سجل إصدار، حواشٍ، مراجع	✓	
2	ترقيم بنود السياسة متسلسل ومرجعه (DAF-POL-ICT-01-01 إلى آخره) دون فجوات أو تكرار	✓	
3	كل حكم نظامي منسوب إلى مرجعه بالحاشية، والحواشي كاملة التعريف	✓	
4	حقول التخصيص معلنة بوضوح وغير قابلة للبتل مع أحكام ملزمة	✓	
5	المرجعية النظامية محينة (تشمل تعديلات 2024–2026م ومسودة الاستطلاع الجاري بصفتها «مسودة» لا نصًا نافذًا)	✓	
6	تغطية دورة حياة البيانات كاملة من الجمع إلى الإتلاف	✓	
7	تغطية الأدوار المطلوبة: مسؤول الحماية، مالك الأصل، المتلقي، المعالج	✓	
8	تغطية الحوادث: احتواء، تقييم ضرر، إشعار 72 ساعة، إخطار أفراد، توثيق	✓	

#	معيار الجودة	متحقق	ملاحظات
9	تغطية النقل عبر الحدود بضماناته وتقييماته ومتابعة المسودة	✓	
10	تغطية الأمن التقني: وصول، تشفير، نسخ احتياطي، شبكات، أجهزة شخصية	✓	
11	النماذج الثلاثة المطلوبة وأكثر موجودة وقابلة للاستخدام المباشر	✓	
12	اللغة عربية فصيحة مركزة، والجداول مختصرة، والعناوين قصيرة محكمة	✓	
13	التواريخ والأرقام النظامية دقيقة (م/19، م/148، 72 ساعة، 30 يومًا، 5 سنوات)	✓	
14	عدم الإغفال عن المتطوعين والمقاولين ومنصات التبرعات	✓	

سجل الإصدار

الإصدار	التاريخ	وصف التغيير	المالك
1.0	2026/11/01	الإصدار الأولي — النسخة الأساسية من حزمة دفة	إدارة الحوكمة والسياسات
2.0	2026/10/31	تحديثات محدودة على الهيكل والمراجع	إدارة الحوكمة والسياسات
3.0	2026/11/06	إعادة بناء شاملة (إصدار مُعمَّق): (1) إعادة الهيكلة على دورة حياة البيانات الكاملة (جمع، تصنيف، غرض، أساس نظامي، إشعار، تقليل، حقوق، احتفاظ، إتلاف)؛ (2) بناء سجل معالجة البيانات (ROPA) وتفصيل تسجيل السجل الوطني للمسؤولين؛ (3) تفصيل أدوار مسؤول حماية البيانات ومالك الأصل والمتلقي؛ (4) توسيع الضوابط التقنية (أقل صلاحية، MFA، مراجعة دورية، تشفير، نسخ احتياطي، شبكات، BYOD)؛ (5) إضافة ملحقات المعالجة والمعالجين من الباطن؛	إدارة الحوكمة والسياسات

الإصدار	التاريخ	وصف التغيير	المالك
		(6) بناء إجراءات حوادث البيانات كاملة (احتواء، تقييم ضرر، إشعار سدايا 72 ساعة، إخطار الأفراد) وفق دليل سدايا أكتوبر 2024م؛ (7) إضافة تقييمات الأثر والمصلحة المشروعة والقرارات الآلية؛ (8) إضافة برنامج التوعية واختبارات الاختراق واستمرارية الأعمال؛ (9) توسيع حقول التخصيص وإضافة قوائم فحص ونماذج (ROPA، بطاقة حادث، قائمة مشاركة، طلب فرد، فحص معالج)؛ (10) تحديث المرجعية بتعديلات 2024–2026م ومسودة اللائحة الجاري استطلاعها حتى 5 نوفمبر 2026م.	

المراجع

194. نظام حماية البيانات الشخصية الصادر بالمرسوم الملكي رقم (م/19) بتاريخ 1443/2/9هـ (16 سبتمبر 2021م)، المعدل بالمرسوم الملكي رقم (م/148) بتاريخ 1444/9/5هـ (27 مارس 2023م) — ومن مواده: المادة (4) حقوق صاحب البيانات، المادة (5) الموافقة وسحبها، المادة (6) المعالجة دون موافقة، المادة (9) بيانات الأطفال، المادتان (23) و(24) البيانات الصحية والائتمانية، المادة (20) إشعار الحادث، المادة (21) الرد على طلبات الأفراد، المادة (22) تقييم الأثر، المادتان (25) و(26) الإعلان والتسويق، المادة (29) النقل خارج المملكة، المادة (31) سجل المعالجة، المادة (32) السجل الوطني، المادة (34) الشكاوى، المادتان (35) و(36) الجزاءات، المادة (40) التعويض.

195. اللائحة التنفيذية لنظام حماية البيانات الشخصية الصادرة عن سدايا (سبتمبر 2024م) — ومن موادها: المواد (3) مهلة الرد على الطلبات، (21) سياسة الخصوصية وعناصرها، (28) و(29) الإعلان والتسويق المباشر، (32) تعيين مسؤول حماية البيانات، المادة الخاصة بسجلات أنشطة المعالجة وحدها الأدنى ومدة الخمس سنوات.

196. لائحة نقل البيانات الشخصية خارج المملكة — الإصدار 2.0 (أغسطس 2024م) — المادتان (3) و(4) تقييم مستوى الحماية، المادة (5) الضمانات المناسبة والبنود التعاقدية النموذجية، المادتان (6) و(7) الاستثناءات ومنعها، المادة (8) تقييم المخاطر.

197. دليل إجراءات حوادث اختراق البيانات الشخصية الصادر عن سدايا (أكتوبر 2024م): مرحلتا الإشعار للجهة المختصة خلال 72 ساعة عبر منصة الحوكمة الوطنية للبيانات، وإخطار أصحاب البيانات دون تأخير مفرط، وبيانات كلٍّ منهما، وواجب المعالج بالإبلاغ الفوري.

198. قواعد السجل الوطني للمسؤولين داخل المملكة الصادرة عن سدايا (2024م): حالات التسجيل الخمس، والشهادة بصلاحية خمس سنوات والتنبيه قبل انتهائها بثلاثين يومًا.

199. قواعد تعيين مسؤول حماية البيانات الشخصية الصادرة عن سدايا (2024م): حالات الوجوب الثلاث وشروط الشاغر وتسجيل بياناته.

200. البنود التعاقدية النموذجية لنقل البيانات الشخصية خارج المملكة (سدايا، سبتمبر 2024م) وقواعد الربط الملزمة.

201. مسودة تعديلات اللائحة التنفيذية لنظام حماية البيانات الشخصية المعروضة للاستطلاع العام (6 أكتوبر – 5 نوفمبر 2026م): مقترحات التخزين داخل المملكة، وتوسيع الإشعار والتسجيل، ومهلة الرد على طلبات سدايا عشرين يوم عمل، وإلغاء مهلة الشكاوى التسعين يومًا، وضوابط التسويق المعززة — تُراقب وتُواءم عند اعتمادها (نفاذها بعد ستين يومًا من النشر).

202. الضوابط الأساسية للأمن السيبراني ECC-2:2024 (الهيئة الوطنية للأمن السيبراني): المجالات الأربعة وضوابطها — الحوكمة (1-1 إلى 1-10)، الحماية (2-1 إلى 2-15)، المرونة (3-1 استمرارية الأعمال)، الأطراف الثالثة والحوسبة السحابية (4-1 إلى 4-6).

203. ضوابط أمن البيانات (DCC) وضوابط أمن الحوسبة السحابية (CCC) الصادرة عن الهيئة الوطنية للأمن السيبراني.

204. المعيار الدولي ISO/IEC 27001:2022 (أنظمة إدارة أمن المعلومات — المتطلبات) وملحقه بضوابطه المرجعية الثلاثة والتسعين في محاورها الأربعة.
205. نظام مكافحة الجرائم المعلوماتية (المرسوم الملكي م/17، 2007م) وتعديلاته.
206. نظام التعاملات الإلكترونية (المرسوم الملكي م/18، 2007م) وتعديلاته.
207. نظام الاتصالات وتقنية المعلومات وتعديلاته.
208. إطار الأمن السيبراني NIST CSF 2.0 (2024م).
209. إطار تبني الذكاء الاصطناعي الصادر عن سدايا (نوفمبر 2025م) ومبادئ أخلاقيات الذكاء الاصطناعي السبعة، وأثرها على معالجة البيانات الشخصية بالأدوات الذكية.
210. الأدلة الإرشادية الصادرة عن سدايا: دليل سياسات الخصوصية، دليل تقليل البيانات، دليل إتلاف البيانات، دليل الإفصاح عن البيانات، دليل مشاركة البيانات، دليل سجلات أنشطة معالجة البيانات.
211. اللائحة التنفيذية لنظام الجمعيات والمؤسسات الأهلية وجزاءاتها المرتبطة بحوكمة الجهات غير الربحية (المادة 86)، وقواعد المركز الوطني لتنمية القطاع غير الربحي ذات الصلة.
212. نظام جمع التبرعات ولائحته التنفيذية وتعليمات المركز الوطني بشأن قنوات الجمع الإلكترونية (فيما يتصل ببيانات المتبرعين).
213. منصة الحوكمة الوطنية للبيانات (dgp.sdaia.gov.sa) وخدماتها: التسجيل، تسجيل مسؤول الحماية، إشعار حوادث البيانات.